

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

index

BACKGROUND.....	3
FIRST.....	3
SECOND.....	4
THIRD.....	4
FOURTH.....	4
FIFTH.....	4
SIXTH.....	4
SEVENTH.....	5
EIGHTH.....	5
Regulatory framework.....	5
System architecture and database. GEA application.....	7
Regarding the chronology of the events. Actions taken to minimize adverse effects and measures adopted for final resolution.....	10
Regarding the causes that made the breach possible.....	13
Regarding the affected data.....	16
Regarding the data processing agreement.....	18
Regarding security measures.....	18
Regarding communication to the affected parties.....	25
Information on the recurrence of these events and the number of analogous events that occurred over time.....	26
NINTH.....	26
TENTH.....	26
ELEVENTH.....	27
TWELFTH.....	29
THIRTEENTH.....	29
FOURTEENTH.....	30

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

PROVEN FACTS.....	30
FIRST: First notification of personal data breach.....	30
SECOND: Second notification of personal data breach.....	30
THIRD: Timeline of the attack.....	31
FOURTH: About the GEA application.....	33
FIFTH: Causes that made the breach possible.....	34
SIXTH: Recommended measures.....	36
SEVENTH: Immediate measures following the breach.....	37
EIGHTH: Security measures implemented prior to the incident.....	38
NINTH: Risk analysis of the processing affected by the personal data breach.....	39
TENTH: Number of affected individuals and type of affected data.....	39
ELEVENTH: Communication to the affected individuals.....	40
LEGAL GROUNDS.....	40
Jurisdiction.....	40

Preliminary issues.....	40
On the request for consolidation and the suspension of the deadline for filing allegations.....	41
Response to the allegations regarding the Initiation Agreement.....	43
FIRST: ON THE CONSOLIDATION OF THE PROCEEDINGS.....	43
SECOND: ON THE SPECIAL CIRCUMSTANCES OCCURRED IN RELATION TO THE PROCESSING OF THIS FILE AND THE VIOLATION OF THE PRINCIPLES OF GOOD FAITH, LEGITIMATE TRUST, AND LEGAL CERTAINTY.....	44
THIRD: ON THE ADDITIONAL IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD.....	49
FOURTH: ON THE ALLEGED VIOLATION BY I-DE OF ARTICLE 32 OF THE GDPR.....	57
FIFTH: ON THE ALLEGED VIOLATION OF ART. 5.1.F) OF THE GDPR.....	63
Response to the allegations regarding the Proposed Resolution.....	68
SECOND: Regarding the prior acts of the AEPD and the violation of the principles of good faith, legitimate trust, and legal certainty.....	69
THIRD: On the arguments put forth by the Proposed Resolution to consider that there is no bis in idem.....	74

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/88

FOURTH: On the application of the principles of sanctioning law to the activity of the AEPD and the concurrence of a medial contest.....	77
FIFTH: On the non-existence of a violation by I-DE of Article 32 of the GDPR.....	82
SIXTH: On the non-existence of a violation of the principle of confidentiality and integrity.....	92
SEVENTH: On the violation of the principle of proportionality to the detriment of the rights of I-DE.....	96
Integrity and confidentiality.....	102
Classification of the infringement of Article 5.1.f) of the GDPR.....	103
Sanction for the infringement of Article 5.1.f) of the GDPR.....	104
Article 32 of the GDPR.....	105
Classification of the infringement of Article 32 of the GDPR.....	110
Sanction for the infringement of Article 32 of the GDPR.....	111

BACKGROUND

FIRST: On March 18, 2022, the Division of Technological Innovation of this Spanish Agency for Data Protection (hereinafter AEPD or the Agency) was notified of a security breach of personal data reported by I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U. with NIF A95075578 (hereinafter, I-DE) as the data controller, in which it informs this Agency of the following:

On the afternoon of March 15, 2022, an attack against the management website for connections (GEA) of I-DE was detected. (...). At this moment, no impact on personal data is identified. The next day, March 16, a brute force attack directed against the same target (GEA) as the incident the previous day was detected. Measures were taken to repel it. On March 17, GEA was reopened, the activity log was analyzed, and it was concluded that there had been an extraction of personal data. It was indicated that the number of affected individuals is 4.5 million customers of this company.

SECOND: On March 29, 2022, I-DE submitted a new notification expanding the information about the security breach reported on the 18th of the same month, indicating that, after a forensic analysis of the

incident, the number of its customers whose data have been affected is 1.35 million and that it is also likely that there are affected data from customers of other companies in the Iberdrola group, as the attacker could potentially have surpassed the security conditions of the information exclusive to I-DE, jumping to ranges of information from other companies, which has already been communicated to the Company's Systems management for a detailed analysis of other impacts on other companies or businesses of the Iberdrola group.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/88

They also indicate that the exact date of the start of the breach is March 7, 2022, and inform that the breach has not yet been communicated to the affected individuals and that, at the latest, they will be informed by March 31, 2022.

Along with the notification, the following is provided:

- Report "Cyber Incident GEA. Incident Description and Actions," which describes the attack suffered and also includes the text of the communication that will be sent to the affected individuals.

THIRD: On March 29, 2022, CURENERGIA COMERCIALIZADOR DE ULTIMO RECURSO SA, with N.I.F. A95554630 (hereinafter CURENERGÍA) submitted a notification of a security breach, indicating that it became aware on March 28, 2022, that it was affected by the security breach suffered by I-DE, indicating the violation of the confidentiality of personal data of 1,550,000 of its customers, whom it has not yet informed but will do so by March 31, 2022, at the latest.

FOURTH: On March 28, 2022, IBERDROLA CLIENTES, S.A., with N.I.F. A95758389 (hereinafter IBERCLI) submitted a notification of a security breach, indicating that it became aware on March 28, 2022, that it was affected by the security breach suffered by I-DE, indicating the violation of the confidentiality of personal data of 85,000 of its customers, whom it has not yet informed but will do so by March 31, 2022, at the latest.

FIFTH: Since April 2, 2022, complaints have been filed with this Agency by customers affected by the security incident, which have been progressively accepted for processing since May 9, 2022.

SIXTH: On April 6, 2022, IBERCLI submitted an extension of the breach notification in which it informs that the individuals affected by it are 1,515,000 and that they were informed of it on March 31, 2022, through communication directed personally to each affected individual (postal, email, SMS, or similar).

Along with the notification, the following is provided:

- Report "Cyber Attack Incident 28/03/2022. Incident Description and Actions"
- Annex Communication to Interested Parties

SEVENTH: On April 6, 2022, CURENERGÍA submitted an extension of the breach notification in which it informs that the individuals affected by it are 92,550 and that they were informed of it on March 31, 2022, through communication directed personally to each affected individual (postal, email, SMS, or similar).

Along with the notification, the following is provided:

- Report "Cyber Attack Incident 28/03/2022. Incident Description and Actions"

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
5/88

-

Annex Communication to Interested Parties

EIGHTH: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in

Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

During the current actions, the following entities have been investigated:

- I-DE REDES ELECTRICAS INTELIGENTES S.A. with NIF A95075578 (hereinafter, I-DE)
- IBERDROLA S.A. with NIF A48010615 with address at C/ TOMAS REDONDO, 1 - 28033 MADRID (MADRID) (hereinafter IBERDROLA)
- IBERDROLA CLIENTES S.A.U. with NIF A95758389 (hereinafter, IBERCLI)
- CURENERGIA COMERCIALIZADOR DE ULTIMO RECURSO S.A. with NIF A95554630 (hereinafter, CURENERGIA)

Regulatory Framework

- The regulatory framework of the electricity sector, Law 54/1997, of November 27, on the Electricity Sector, imposes an obligation of total separation between regulated activities, such as distribution, and liberalized activities, such as commercialization.

- The right that electricity consumers have to access and connect to the electricity transport and distribution networks in Spanish territory is specifically set forth in Law 24/2013, of December 26, on the Electricity Sector.

Distribution companies and marketing companies are two distinct entities within the Electricity Sector. In this regard, Law 24/2013, of December 26, on the Electricity Sector defines them as different subjects.

- According to the regulation of the electricity sector, the consumer, in order to receive electricity at their home, needs to hold two differentiated contracts concerning their supply point (CUPS):

☐ On one hand, the energy purchase contract, "supply contract," which is signed between a consumer and an electricity marketing company.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/88

Although it is also possible for the consumer to purchase electricity directly in the market, without the need for a marketer, this is not typical for individual consumers but rather for large electricity-consuming companies, as indicated by I-DE, IBERCLI, and CURENERGÍA in their response.

☐ On the other hand, the network access contract or distribution or transport contract, "ATR contract," which the consumer signs with the intermediation as a representative of the marketing company with which they have contracted the purchase of electricity.

Although it can also be signed directly with the company that owns the network, this is not typical for individual consumers but rather for large electricity-consuming companies, as indicated by I-DE, IBERCLI, and CURENERGÍA in their response.

- When a customer wishes to contract electricity at a supply point or make any contractual modification, that customer approaches a marketer, who on behalf of the customer and as their representative contracts in their name the ATR contract, the network access contract.

Any contractual modification requested by a marketer from a distributor is carried out through digital XML requests complying with the exchange formats between agents established by the National Commission on Markets and Competition (CNMC), by virtue of the Resolution of December 20, 2016, which approves the formats of the information exchange files between electricity and natural gas distributors and marketers, and the Resolution of December 17, 2019, which approves new formats of the information exchange files between distributors and marketers and modifies the Resolution of December 20, 2016.

Taking the above into account:

- I-DE, the electricity distributor of the Iberdrola group, states that it can only access the data of its customers, that is, of the users of the electricity service whose supply point is within the network managed by it as a distributor, and not those managed by other distribution companies.

In relation to the users of its network, it knows the data of the marketer of each consumer as a result of

the signing of the ATR contract with them (or with the marketer as the representative of the consumer).
- I-DE indicates that it would not have the capacity to know any type of information related to those who, being customers of IBERCLI or CURENERGIA, electricity marketers of the Iberdrola group in the free market and regulated market, respectively, are not customers of this distributor.

System Architecture and Database. GEA Application

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/88

(...)

IBERDROLA indicates that the audit verifying the logical separation of access to information by I-DE is based on the provisions established in the regulatory framework of the electricity sector, which imposes a total separation obligation between regulated activities, such as distribution, and liberalized activities, such as marketing, in such a way that distribution companies must demonstrate this separation.

I-DE reports that it issues an annual report presented to the Ministry for Ecological Transition and the Demographic Challenge (MITERD) and the National Commission on Markets and Competition (CNMC) to account for compliance with obligations regarding the separation of activities by the group companies formed by Iberdrola España and the companies in which it participates with regulated activities, namely, the company I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U., Article 12.2 b) of the Electricity Sector Law and Article 14 of the Activity Separation Code of the Iberdrola España Group Companies with Regulated Activities ("CSA") available on the Iberdrola España website, during the fiscal year.

(...)

Regarding the chronology of events. Actions taken to minimize adverse effects and measures adopted for final resolution.

I-D states the following:

- On March 15, in the afternoon, an attack was detected against the management website for I-DE connections (GEA), with the sequence of events as follows:

☐

(...)

- On March 16, 2022, in the morning, a general slowdown in access to several Iberdrola group websites occurred.

☐

(...)

- From March 17, 2022:

☐

(...)

☐ From March 17, no suspicious traffic or impact was observed in any of the internet service systems of the Iberdrola group.

☐ An analysis of the activity log of the GEA application from the last few days concludes as of March 17 that an exfiltration occurred, between March 7 and March 15, 2022, of approximately 4.5 million interested parties (natural persons).

☐

(...)

☐ On March 28, 2022, the Systems Management informed IBERCLI and CURENERGIA of the existence of a security incident in the I-DE systems that may have affected information related to the clients of these companies and includes information related to the internal client codes of the affected parties, so that the companies can verify whether data corresponding to their clients may have been compromised. After analyzing the information, IBERCLI and CURENERGIA confirmed that the security breach affected personal data of clients of these companies.

☐

(...)

- Furthermore, I-DE states and certifies that since becoming aware of the incident, necessary actions were implemented to, in coordination with the affected organizations, comply with the established internal protocols and applicable legislation, which include the following actions:

☐ Communication to INCIBE-CERT, the National Cybersecurity Institute in Spain, as the reference incident response team for Iberdrola.

☐ Communication to the Cyber Coordination Office, under RDL 12/2018 on the security of networks and information systems, which refers the cybersecurity incident to the National Police for investigation.

☐ Communication to the National Center for the Protection of Critical Infrastructures under Law 08/2011 on the protection of Critical Infrastructures.

☐ Filing a complaint with the National Police (Central Cybercrime Unit) and the document submitted by I-DE along with it.

☐ Notification of the security breach to the AEPD and to the affected parties.

- In summary, the monitoring systems allowed for the detection of an anomalous volume of traffic, a more detailed analysis activity was initiated, and the immediate measures that were adopted were:

☐

(...)

- IBERCLI and CURENERGIA state that the cessation of the incident occurred even before they became aware that it had affected personal data related to their clients, with this cessation being a consequence of the additional security measures implemented by the Systems Management in the GEA application, aimed at preventing information from the Database related to clients of other Group entities from being exfiltrated through access to it by introducing a random code.

Regarding the causes that made the breach possible

- (...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/88

Regarding the affected data

-

The exfiltrated customer data (...):

☐ Name

☐ Surname

☐ E-mail

☐ Fax

☐ Phone

☐ Address

☐ NIF/DNI

☐ Customer Code

☐ (...).

-

(...)

On March 28, 2022, the Systems Management informed IBERCLI and CURENERGIA of the existence of a security incident in the I-DE systems that may have affected information related to the customers of these companies and included information regarding the internal customer codes of the affected parties, so that the companies could verify whether data corresponding to their customers may have been compromised.

IBERCLI and CURENERGÍA verified that the security breach affected personal data of 1,515,000 and 92,550 customers, respectively.

Regarding the data processing agreement

-

The Framework Agreement on Personal Data Protection of the Iberdrola Group is provided, detailing the scope of the services provided to the Group companies by IBERDROLA. This agreement has been updated in its Annex II, with said update pending formalization.

Additionally, the Acceptance Declaration of Iberdrola España S.A.U. regarding its adherence to the Framework Agreement on Personal Data Protection of the Iberdrola Group is provided, with the aforementioned entity acting, as indicated in the second clause, in its own name and right and on behalf of the companies belonging to its corporate group over which it holds direct or indirect control, including I-DE, IBERCLI, and CURENERGIA.

-

IBERCLI and CURENERGIA provide a copy of the record of the activities of processing personal data corresponding to the treatments affected by the breach:

☐ (...)

-

IBERDROLA provides a copy of the records of the activities of processing corresponding to the treatments "IT Infrastructure Support and Maintenance" and "Application Development (SWF)", which it carries out in its capacity as data processor, regarding various treatments of the Group companies, including those affected by the security breach.

Regarding security measures

Regarding the risk analysis conducted on the processing activity that suffered the security breach prior to the occurrence of the breach:

-

IBERDROLA states in its response letter that the Iberdrola Group has adopted a risk analysis methodology for personal data processing that is implemented automatically in the corporate activity record tool itself, so that the level of risk of the processing is determined in the registration process itself.

-

In the case of the treatments for which IBERDROLA acts as the data processor, it indicates that the methodology involves conducting a risk analysis in relation to each of the treatments for which IBERDROLA holds that status, so that this analysis is developed by the entity responsible for the processing in collaboration with IBERDROLA.

-

For this reason, the result of the risk analysis related to the specific treatments ***TREATMENT.1 and ***TREATMENT.2 is incorporated into the Activity Records of I-DE and those of IBERCLI and CURENERGIA, with the results having been communicated to IBERDROLA.

(...)

- Measures of security implemented prior to the breach in the data treatments where it occurred:

I-DE, IBERCLI, and CURENERGIA indicate in their responses that prior to the incident, the following security measures common to the IT infrastructure of the Iberdrola Group were implemented:

-

(...)

Likewise, as with IBERDROLA, they also describe the specific security measures of the GEA system:

-

(...)

Measures adopted to prevent, as much as possible, incidents like the one that occurred

- With the data obtained from the cyberattack methodology, (...).

Regarding communication to the affected parties

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/88

-

I-DE informs the Systems Directorate, on March 28, 2022, that, from the information provided

regarding the customer codes of those affected by the breach, only 1.34 million records correspond to I-DE customers.

Furthermore, it determines that it will proceed to communicate the security breach to the affected individuals through the communication channels that I-DE maintains with them. The communications were sent via email; to the customers for whom it had email addresses, through several mailings between March 31 and April 12, 2022; and by postal mail to the remaining customers between March 30 and April 7, 2022.

-

On March 28, 2022, the Systems Directorate informs IBERCLI and CURENERGIA of the existence of a security incident in the I-DE systems that may have affected the information related to the customers of these companies and includes information regarding the internal customer codes of the affected individuals, so that the companies can verify if data corresponding to their customers may have been compromised.

IBERCLI and CURENERGÍA report that after analyzing the information by their respective systems teams, they verify that the security breach has affected personal data of 1,515,000 and 92,550 customers, respectively.

Furthermore, they resolve to notify the affected individuals of the security breach. The notification to the affected individuals was carried out, between March 31 and April 1, 2022, to the customers for whom email addresses were available, through the mass sending of electronic communications; and by postal mail to the remaining customers on April 4 and 5, 2022.

-

The three companies provide the model of communication sent to the affected individuals, and it is verified that it complies with the specifications in Article 34 of the GDPR.

Information regarding the recurrence of these events and the number of analogous events that have occurred over time.

IBERDROLA states that aside from the security incident subject to this procedure, no other incident of a similar nature has occurred.

NINTH: The entity I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U. is a large company established in 2000, with a turnover, according to AXESOR, of ***AMOUNT.1 euros in 2021 and ***AMOUNT.2 euros in 2022.

TENTH: On May 5, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against I-DE, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/88

The aforementioned Initiation Agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

ELEVENTH: On May 24, 2023, I-DE submitted a written request for the accumulation of the present file with EXP202305587, as well as the suspension of the deadline for the submission of allegations until this request is resolved, indicating the following:

I-DE understands that the facts that serve as the basis for the exercise of the sanctioning power that the Agency seeks to exercise are or have a unique basis that affects both sanctioning files that have been opened as differentiated, and therefore requests the accumulation of both sanctioning procedures, understanding that there is a necessary connectivity between them, that is, it concerns the same situation that may result in the responsibility of both. I-DE understands that the terms of such responsibility, total, partial, in the degree of author, collaborator, or any other that may arise from the criminal references can only be assessed if the procedure is analyzed as a whole.

I-DE argues that the lack of accumulation in the present case could imply a double imputation to two entities of the same facts, which moreover belong to the same business group, specifically the Iberdrola group of which IBERDROLA is the parent company.

If both files are not accumulated, I-DE states that it would prevent clarifying the degree of responsibility of each of them, since the facts would be analyzed separately and without assessing the alleged simultaneous action, in terms of responsibility, of the two entities against which both procedures are directed. In this way, there could be a double imputation of the same facts to both entities without assessing whether it is shared or whether the separate sanctioning reproach directed against both should not be subject to reduction as a consequence of that alleged concurrence of responsibility. This limits, in the terms established in the constitutional jurisprudence that is reproduced below, the right to defense of I-DE, as it cannot analyze the concurrent circumstances in the case in a unified manner as a consequence of the fragmentation caused by the opening of two differentiated procedures.

I-DE understands that the prerequisites established in Article 57 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) that justify the accumulation of the procedures, as well as the individualization of the relevance of its application to the present case, are met:

A) Existence of "intimate connection" or "substantial identity."

I-DE points out that, in the present case, on March 18, 2022, there was a breach of personal data security, initially reported by I-DE. It is this same security breach that determines the opening of the present procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/88

in which responsibility is attributed to i-DE, as well as that of the one intended to be accumulated with the present, opened to clarify the responsibility of IBERDROLA. i-DE indicates that connectivity, in the present case, derives from the fact that it involves determining the responsibility of two legal entities, but for the same fact: it is the Agency itself that makes it clear that it concerns a single security breach and that it is on this basis that the subjective responsibilities of i-DE, in the present procedure, and of IBERDROLA in the procedure whose accumulation is requested will be founded, if applicable.

Therefore, i-DE concludes that, given that there are unique facts for which responsibility is attributed to both i-DE and IBERDROLA, it is evident that a joint assessment of the same is necessary to determine whether there is joint or separate responsibility of both entities, as well as whether the responsibility would be under different titles in each case.

B) That the same body is responsible for the processing and resolution of the procedure.

i-DE points out that, along with the previous requirement, the LPACAP imposes respect for the general principle of competence of the body that must issue the resolution, a requirement that is met in the present case, given that the Law attributes the competence for the processing of both procedures to a single sanctioning body, so that with the accumulation, that competence is neither lost nor blurred as a consequence of the potential existence of different instructing bodies.

In i-DE's opinion, the essential effect of the accumulation of files is that all issues to be resolved must be examined in a single procedure and decided in a single final act that jointly assesses the responsibilities of all those involved.

i-DE notes that the scheme just analyzed undoubtedly has special characteristics in the sanctioning field due to its own structure and the value judgment that it entails.

It brings up several rulings from the Constitutional Court to highlight that the main principles and constitutional guarantees of criminal law and criminal procedure must be observed, with certain nuances, in the sanctioning administrative procedure, such as the right to be informed of the accusation (SSTC 31/1986, 190/1987, 29/1989) and to use relevant means of evidence for the defense (SSTC 2/1987, 190/1987, and 212/1990), as well as the right to the presumption of innocence (SSTC 13/1982, 36 and 37/1985, 42/1989, 76/1990, and 138/1990), all fundamental rights that have

been incorporated by the legislator into the regulatory framework of the common administrative procedure.

I-DE understands that the fragmentation of the procedure into two separate procedures substantially affects the determination and verification of the relevant facts therein, as well as the delimitation of the potential responsibilities that may correspond to the entities to which the procedures whose accumulation is requested are directed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/88

I-DE concludes that the accumulation is a requirement for adequate instruction and the guarantee of the right to defense, and that the separate processing of two sanctioning files against two different legal entities for the same facts is detrimental to their interests.

I-DE understands that the lack of accumulation in the present case could imply a double imputation to I-DE and IBERDROLA, as mentioned, for the same facts, without the accumulation allowing to clarify what the degree of responsibility of each of them would be, since the facts would be analyzed separately and without assessing the alleged simultaneous action, in terms of responsibility, of the two entities against which both procedures are directed.

It understands that maintaining the separation of the procedures implies, in procedural terms, a fragmentation of the cause that conditions the instructive and proposal action because different instructions, evaluations, and potentially different evidence appear, and therefore, criteria that can also be differentiated.

For all the above, I-DE requests the accumulation of the two cited files and that the suspension of the deadline for the formalization of allegations be expressly requested until the accumulation incident raised in this document is resolved.

Furthermore, I-DE understands that, considering the nature of what is requested and the impact on the instruction of the files in question and, ultimately, on the right to defense of the interested parties in both procedures, as it substantially affects the content of the allegations that I-DE could make in the event that the aforementioned accumulation is agreed upon, with the consequent reduction of its right to effective judicial protection in its modality of using the necessary means of evidence for the adequate defense of its rights, we expressly request the suspension of the deadline for the formalization of allegations so that they can be made in accordance with the instructive criteria that we are requesting.

Therefore, I-DE requests the suspension of the deadline for the formalization of allegations until the accumulation incident raised in this document is resolved.

TWELFTH: On May 30, 2023, I-DE submitted a written statement of allegations regarding the Initiation Agreement.

THIRTEENTH: On January 2, 2024, a Proposal for Resolution was formulated, proposing that the Director of the Spanish Agency for Data Protection sanction I-DE REDES ELÉCTRICAS

INTELIGENTES, S.A.U. with NIF A95075578, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, with an administrative fine of 2,500,000 euros (two million five hundred thousand euros) and for an infringement of Article 32 of the GDPR, classified under Article 83.5 of the GDPR, with a fine of 1,000,000 euros (one million euros).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/88

FOURTEENTH: On January 22, 2024, a written statement from I-DE was received by this Agency, in due time and form, in which it presents allegations to the proposal for resolution.

From the actions carried out in the present procedure and from the documentation in the file, the

following has been accredited:

PROVEN FACTS

FIRST: First notification of personal data breach

On March 18, 2022, I-DE notified the AEPD of a personal data breach in which it informs the following:
(...)

It is indicated that the number of affected individuals is 4.5 million customers of this company.

It indicates the start date of the breach as March 9, 2022.

It indicates the date of detection of the breach, understood as the date on which the responsible party is certain that personal data has been affected: March 17, 2022.

SECOND: Second notification of personal data breach

On March 29, 2022, I-DE submitted a new notification expanding the information about the previously notified personal data breach, through the submission of the report "Cyber Incident GEA. Incident Description and Actions." dated March 28, 2022, according to which:

"I-DE, within the provision of services to its customers, offers a web application called Management of Files and Connections (GEA): ***URL.1

This service allows customers or their representatives (installers) to carry out the necessary procedures for the process of a connection to the network. During the sessions of the application, there is an exchange of customer data information that is subject to the security filters of the application, so that each customer (or delegated representative) can only access the information corresponding to the security and access profiles provided.

It indicates that the number of affected customers of this company is 1,350,000.

It indicates the start date of the breach as March 7, 2022.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/88

THIRD: Chronology of the attack

According to I-D, in the report "Cyber Incident GEA. Incident Description and Actions," dated March 28, 2022, and submitted along with the second notification of a personal data breach, as well as in the response to the information request made by this AEPD, during the preliminary investigation proceedings presented on August 1, 2022 (Registration Number: REGAGE22e00033475096), the chronology of the attack is as follows:

- "On March 15, in the afternoon, an attack against the management website of I-DE's connections (GEA) is detected.

☐

(...)

- On March 16, 2022, in the morning, a general slowdown in access to several websites of the Iberdrola group occurs.

☐

(...)

- From March 17:

☐

(...)

☐

From March 17, no suspicious traffic or impact is observed in any of the internet service systems of the Iberdrola group.

☐

From the analysis of the activity log of the GEA application in the last few days, it is concluded on March 17 that an exfiltration occurred between March 7 and March 15, 2022, affecting approximately 4.5 million individuals (natural persons).

☐

(...)

□

On March 28, 2022, the Systems Directorate informs IBERCLI and CURENERGIA of the existence of a security incident in I-DE's systems that may have affected information related to the clients of these companies and includes information regarding the internal client codes of the affected individuals, so that the companies can verify whether data corresponding to their clients may have been compromised. After analyzing the information, IBERCLI and CURENERGIA confirm that the security breach has affected personal data of clients of these companies.

□

(...)

FOURTH: Regarding the GEA application

Regarding the GEA application, I-DE states:

In the report "Cyber Incident GEA. Incident Description and Actions," dated March 28, 2022:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/88

- "I-DE, within the provision of services to its clients, offers a web application called Management of Files and Connections (GEA): ***URL.1

This service allows clients or their representatives (installers) to carry out the necessary procedures for the process of connecting to the network. During the sessions of the application, there is an exchange of client data information that is subject to the security filters of the application, so that each client (or delegated representative) can only access the information corresponding to the security and access profiles provided."

- "I-DE has a system (SIC) of which GEA is a web service, proprietary and exclusive for the processing of its processes and client data, with the business and systems teams responsible for the development, evolution, and maintenance of this system, also exclusive to I-DE."

- "In the 'Client Access Manual, GEA,' provided by I-DE, the methodology for registering a user is described (Document No. 6 of entry REGAGE23e00004673128), in which it is indicated that for the development of the process of registering a new user, a valid and accessible email address is required, to which an individualized link is automatically sent for each user, allowing them to set the password for the first access, thus validating the registration in the application."

- "In the response to the information request made by this AEPD, submitted on February 21, 2023 (Registration Number: REGAGE23e00011000318), I-DE indicates:

(...)

This URL was displayed to validated users at the time of the incident.

IBERDROLA S.A., which provides various services to I-DE and other companies in the Group, including "IT infrastructure support and maintenance" and "Application development," acting accordingly as the data processor for I-D, in its response to the information request made by this AEPD during the preliminary investigation period, submitted on January 24, 2023 (Registration Number: REGAGE23e00004670187), in response to the request for information regarding the description of control and access permissions to the application for each of the identified profiles, IBERDROLA responds:

(...)

FIFTH: Causes that made the breach possible

In the "Summary Forensic Report Security Incident GEA," dated March 23, 2022, provided by I-DE along with its response to the information request made by this AEPD, submitted on August 1, 2022 (Registration Number: REGAGE22e00033475841), it is indicated:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/88

-I-DE indicates the following:

(...)

-IBERDROLA S.A., which provides various services to I-DE and other companies in the Group, including "IT infrastructure support and maintenance" and "Application development," acting consequently as the data processor for I-D, in its response to the information request made by this AEPD during the preliminary investigation period, submitted on January 24, 2023 (Registration number: REGAGE23e00004670187), indicates the following:

(...)

SIXTH: Recommended measures

The document "Summary of Forensic Report on Security Incident GEA," dated 03/23/2022, provided by I-DE in its submission of 08/01/2022, includes the following recommendations:

(...)

SEVENTH: Immediate measures following the breach

I-DE, in its response to the request made by this AEPD, submitted on February 21, 2023 (Registration number: REGAGE23e00011000318), indicates:

(...)

IBERDROLA, S.A., in its response to the information request made by this AEPD during the preliminary investigation period, submitted on January 24, 2023 (Registration number: REGAGE23e00004670187), attaches as "Document No. 11," the "Urgent Cybersecurity Plan." In it, the following measures are indicated, among others: Application Security:

(...)

EIGHTH: Security measures implemented prior to the incident

Among others, the following was provided:

(...)

NINTH: Risk analysis of the processing affected by the personal data breach

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/88

At the request of this AEPD for a copy of the risk analysis concerning the rights and freedoms of individuals conducted on the processing activity that suffered the security breach prior to the incident, I-DE provided the framework followed within the Iberdrola Group for assessing the risk in the processing of personal data.

It provides this framework, detailing certain threats or circumstances such as "vulnerable groups," "access to personal data by more than 10 people," "international transfers," "large-scale processing," "profiles with legal effects." These circumstances are established as questions, and depending on whether the answer is "yes" or "no," a result is applied.

It also indicates that "Attached, as Document No. 8, is an explanatory document of the logic followed for calculating the level of risk according to this methodology. This methodology is implemented in an automated manner within the corporate tool for recording processing activities, so that in the registration process itself, it determines the level of risk of the processing. Thus, the application of this methodology in relation to the processing ***PROCESSING.1 resulted in a MEDIUM risk level, as recorded in Document No. 7 referred to above.

In Document 8, circumstances or threats are analyzed in accordance with the indicated framework, which are transferred to the Register of Processing Activities.

TENTH: Number of affected individuals and type of affected data

1,350,000 customers of I-DE affected.

Type of affected data:

Name and surname

Email address
Fax number
Phone number
Postal address
NIF/DNI

Customer code
Company code

ELEVENTH: Communication to the affected individuals

In the response to the information request made by this AEPD during the preliminary investigation proceedings, submitted on August 1, 2022 (Registration number: REGAGE22e00033475096), I-DE states that it has communicated the personal data breach to the affected individuals, indicating:

"The aforementioned communications were sent to the i-DE customers for whom an email address was available through this medium by making several dispatches between March 31 and April 12 of C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/88

2022, notifying the breach by ordinary mail to the remaining clients between March 30 and April 7, 2022."

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

I-DE is a large company of the Iberdrola Group dedicated to the distribution of electric energy and, for this purpose, processes personal data as the controller of a very high number of individuals, as it states that it processes data from 21 million clients.

Therefore, in accordance with the provisions of Article 4.1 of the GDPR, there is a processing of personal data, since I-DE carries out, among other processes, the collection, storage, consultation, use, deletion, etc., of personal data of individuals, such as: name, surname, ID number, postal address, telephone number, email address, banking data, data related to electricity supply and consumption, bank account, etc.

Additionally, IBERDROLA S.A. provides various services to I-DE and other companies in the Group, including "IT infrastructure support and maintenance" and "Application development," acting consequently as the data processor for I-DE.

In the case at hand, the security breach suffered has affected personal data processed by I-DE in its capacity as the data controller, determining the purposes and means regarding those processes, by virtue of Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or to the unauthorized

communication or access to such data.”

In this case, there is a personal data security breach under the circumstances mentioned above, categorized as a confidentiality breach, due to unauthorized access by a third party to personal data processed by I-DE.

III

On the Request for Joinder and Suspension of the Deadline for Submitting Allegations

Regarding the request for the joinder of this file and EXP202305587 made by I-DE, it should be noted that Article 57 of the LPACAP establishes:

“The administrative body that initiates or processes a procedure, regardless of the form of its initiation, may, ex officio or at the request of a party, order its joinder to others that have substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure. No appeal shall proceed against the joinder agreement.”

(the underlining is ours)

Therefore, it is a possibility that the Administration has, not being obliged to proceed with the joinder if requested. However, this does not prevent the subsequent motivation of the reasons why it has been deemed appropriate to process both sanctioning procedures separately.

Thus, although the two sanctioning files, one directed against I-DE and the other against IBERDROLA, S.A., stem from the same security incident (the attack on the GEA application), it has produced two different and differentiated personal data breaches, as reflected in the Background Facts of this proposal, especially in Background Fact Eight, where the information gathered during the preliminary investigation phase carried out by this AEPD is noted.

Thus, on one hand, the attack was initiated through a web application of I-DE, exploiting a vulnerability that allowed access to I-DE's database and affected the confidentiality of 1,350,000 clients of I-DE.

22/88

Therefore, the present sanctioning procedure is directed exclusively at I-DE as the responsible party for the processing of personal data of its clients and as a consequence of an existing vulnerability in one of its web applications.

On the other hand, the cyberattack not only affected personal data of I-DE, but also, by accessing I-DE's database, which was hosted on a system where databases of other companies in the same group coexist, it was possible to surpass the logical separation and access the databases of two other companies, IBERCLI and CURENERGÍA, affecting the confidentiality of personal data of clients of these two latter companies. These different databases of different companies are hosted or operated on a system maintained and supported by IBERDROLA, S.A., which, consequently, is responsible for the processing of all of them, that is, of I-DE, IBERCLI, and CURENERGÍA.

This fact has led to the initiation of a sanctioning procedure against IBERDROLA, S.A., but for its responsibility as the processor for IBERCLI and CURENERGÍA and exclusively for the personal data breach that has only affected the personal data of clients of these two marketing companies, and solely considering the responsibility that IBERDROLA, S.A. may have regarding the configuration of the databases it manages concerning these two affected companies.

In this regard, the impact on personal data of clients hosted in databases not belonging to I-DE cannot be part of this sanctioning procedure directed exclusively at examining the conduct of I-DE, since it is not responsible for the personal data of affected clients belonging to other companies, nor for the possible failure to adopt appropriate measures for their protection or for the absolute separation between them. Therefore, the management of the databases carried out by IBERDROLA, S.A. regarding those third companies must be analyzed independently, without I-DE being held accountable for possible breaches of data protection regulations that those third companies may have incurred.

This was stated by I-DE in its response to the request made by this AEPD, submitted on August 1, 2022, in which, when asked for information about the data affected by the breach relating to clients of IBERCLI and CURENERGÍA, it responded that “I-DE does not have access to the data of individuals who may have been affected by the security breach and who are not clients of the aforementioned

entity as their supply point is not assigned to the network managed by I-DE. This means that I-DE does not have the capacity to know any type of information related to those who, being clients of IBERCLÍ or CURENERGÍA, are not clients of this distributor.”

Therefore, since the sanctioning procedures are directed at different subjects (two different companies), with the personal data of clients of different companies being affected, and I-DE having nothing to do with the data of external clients, and given that the processing relates to vulnerabilities or breaches regarding different systems (one a web application, the other a database), etc., this AEPD has not considered it appropriate to accumulate the two files, but rather to process the two sanctioning procedures separately, as the responsibility is clearly separated.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/88

which is attributed to each one, as well as the fact that they concern different personal data breaches affecting personal data processed by different controllers.

Furthermore, this does not leave I-DE defenseless, as it is always aware of the facts attributed to it, the infringement that these imply, their classification, the responsibility incurred, as well as having had and having the opportunity to make allegations and present any documentation it deems appropriate in defense of its interests as permitted by the applicable legislation.

Finally, regarding the request to suspend the deadline for making allegations to the Initiation Agreement until a decision is made on the accumulation of the two procedures, it is noted that such a possibility does not exist either in the applicable data protection regulations (GDPR and LOPDGD) or in the LPACAP. On the contrary, this latter law establishes the obligation that the procedures to be completed by the interested parties are mandatory:

“Article 73. Compliance with procedures.

1. The procedures that must be completed by the interested parties must be carried out within ten days from the day following the notification of the corresponding act, unless a different deadline is set in the corresponding regulation.”

Therefore, the request for suspension is not appropriate, as this possibility does not legally exist, nor has it had any effect, and consequently, the deadline for making allegations has not been suspended.

IV

Response to the allegations regarding the Initiation Agreement

In response to the allegations presented by I-DE, the following should be noted:

FIRST: ON THE ACCUMULATION OF THE PROCEDURES

I-DE reiterates the request for accumulation and refers to the request submitted for this purpose on May 24, 2023.

In this regard, it is appropriate to refer to the arguments made in the previous Legal Basis, which adequately addresses this issue.

SECOND: ON THE SPECIAL CIRCUMSTANCES OCCURRED IN RELATION TO THE PROCESSING OF THIS FILE AND THE VIOLATION OF THE PRINCIPLES OF GOOD FAITH, LEGITIMATE TRUST, AND LEGAL SECURITY

I-DE alleges that this AEPD has violated the principles of legal security, good faith, and legitimate trust established in Article 3.2 e) of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter LRJSP) since, by means of a letter dated April 18, 2022, from the Division of Technological Innovation of the AEPD, it is indicated, in relation to the additional information provided by I-DE regarding the personal data breach suffered by it, that “After analyzing the information

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/88

additional information provided, the security breach has been updated in the security breach

notification register and no further actions are anticipated by this Agency,” but subsequently, and without any subsequent action recorded up to the date of the first request for information directed to it (written document signed on July 8, 2022, by the acting Inspector), it appears that the AEPD initiated investigative actions, without any agreement or decision in this regard.

I-DE understands that this demonstrates that no additional investigation related to the breach was warranted since the AEPD, by signing the aforementioned document of April 18, deemed the statements made by I-DE adequate, not perceiving in the breach the presence of any element that would justify conducting investigative actions aimed at determining whether a presumed violation of data protection regulations had occurred.

However, I-DE continues, on May 9, 2022, the AEPD agreed to admit claims (filed prior to April 18, 2022) and to initiate preliminary investigative actions, but there is no record in the file of any action or circumstance related to this case that had been provided or occurred in the period between April 18 and the date of admission that justifies the initiation of the same.

Furthermore, I-DE understands that the document of May 18, 2022, implies that the AEPD considered the information received from it regarding the breach to be sufficient to conclude that there was no responsibility for any alleged breach of data protection regulations, which determined the filing of a case that, however, the AEPD decided to open days later without any indication that implies a substantial change in the nature, circumstances, or severity of the breach. From this, I-DE concludes that the AEPD adopted a decision that directly contradicts the previous one made just 20 days earlier. In this regard, it should be noted that I-DE's interpretation of the document received on May 18, 2022, cannot be accepted in any way. Thus, this document is generically signed by the AEPD, comes from the Division of Technological Innovation, which is responsible for receiving security breaches and registering them in the relevant register, and in which the following was indicated:

“In relation to the additional information provided through entry register REGAGE22e00010072289, regarding a personal data breach in a processing by I-DE REDES ELECTRICAS INTELIGENTES S.A.U., we inform you that:

After analyzing the additional information provided, the security breach has been updated in the security breach notification register and no further actions are anticipated by this Agency.

However, we remind you of the necessity to investigate the causes of the incident until understanding how and why it occurred, and the obligation to take appropriate actions to prevent it from happening again and to minimize the impact.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/88

potential impact on those affected, as well as the obligation to document any security incident that may affect personal data, including the facts related to it and the corrective measures taken, as established in Article 33.5 of the GDPR.

If, over time, indications arise that imply a substantial change in the nature, circumstances, or severity of the breach, a new complete notification may be made through our electronic headquarters at <https://sedeagpd.gob.es/sede-electronica-web/>.

Furthermore, we inform you that at the following link you have available the guide for the management and notification of personal data security breaches published by this Agency:

<https://www.aepd.es/media/guias/1ome-brechas-seguridad.pdf>

The heading states "DIVISION OF TECHNOLOGICAL INNOVATION."

On the left side of the document, it indicates that "Electronically signed by: Spanish Agency for Data Protection. Dated 18/04/2022."

It is not signed by the Director of the Agency, it does not have a dispositive part in which something is agreed or resolved, nor does it indicate any appeal against it.

Therefore, and contrary to what I-DE claims, this document does not have a decisional character, neither by its content, which only contains a forecast and cannot be understood to imply that this AEPD has assessed and decided that there was no responsibility on the part of I-DE for an alleged breach of

data protection regulations, which would imply the filing of certain proceedings—as I-DE has wanted to understand—nor by its form, since it does not even formally reflect a decision, much less a resolution to archive any proceedings, as the only competent body for this is the current Director of the AEPD. Thus, Article 13 of the Statute of the AEPD, approved by Royal Decree 389/2021, of June 1, establishes the functions of the Presidency:

1. It is the responsibility of the Presidency of the Spanish Agency for Data Protection:

d) To issue the resolutions and guidelines required for the exercise of the Agency's functions, particularly those arising from the exercise of the competencies provided for in Article 57 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and from the exercise of the investigative powers and corrective powers provided for in Article 58 of the aforementioned Regulation.

Therefore, to proceed with the filing of investigative proceedings, it is required, first, that they have been initiated (either by having accepted a complaint for processing or by own initiative, which in both cases requires an express resolution signed by the Director), which had not occurred at the time of issuing the aforementioned document from the Division of Technological Innovation, and, secondly, it is again necessary to have an express resolution from the Director archiving said proceedings by understanding, now indeed, that from the information gathered in those investigations, no infringement of data protection regulations is concluded, which had not occurred.

In this case, following the notification of the personal data breach by I-DE, several complaints were filed by individuals affected by it, which were jointly admitted for processing by the AEPD in compliance with Article 64 of the LOPDGDD:

Article 64. Form of initiation of the procedure and duration.

1. When the procedure refers exclusively to the lack of attention to a request for the exercise of the rights established in Articles 15 to 22 of Regulation (EU) 2016/679, it will be initiated by an admission agreement, which will be adopted in accordance with the provisions of Article 65 of this organic law. In this case, the deadline for resolving the procedure will be six months from the date on which the agreement of admission to processing was notified to the complainant. After this period, the interested party may consider their complaint accepted.

2. When the procedure aims to determine the possible existence of an infringement of the provisions of Regulation (EU) 2016/679 and this organic law, it will be initiated by an initiation agreement adopted by its own initiative or as a result of a complaint. If the procedure is based on a complaint filed with the Spanish Agency for Data Protection, beforehand, it will decide on its admission for processing, in accordance with the provisions of Article 65 of this organic law. When the rules established in Article 60 of Regulation (EU) 2016/679 apply, the procedure will be initiated by adopting the draft initiation agreement for sanctioning proceedings, which will be formally communicated to the interested party for the purposes provided for in Article 75 of this organic law. Once the complaint has been admitted for processing, as well as in cases where the Spanish Agency for Data Protection acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions, which will be governed by the provisions of Article 67 of this organic law.

Article 67. Preliminary investigative actions.

1. Before the adoption of the initiation agreement of the procedure, and once the complaint has been admitted for processing if there is one, the Spanish Agency for Data Protection may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/88

The Spanish Agency for Data Protection shall act in any case when it is necessary to investigate processing that involves massive traffic of personal data.

2. The preliminary investigative actions shall be subject to the provisions of Section 2 of Chapter I of Title VII of this organic law and may not exceed a duration of twelve months from the date of the

admission agreement for processing or from the date of the agreement that decides its initiation when the Spanish Agency for Data Protection acts on its own initiative or as a consequence of the communication that has been sent to it by the supervisory authority of another Member State of the European Union, in accordance with Article 64.3 of this organic law. (the underlining is ours)

From this regulation, it cannot be inferred in any way that the AEPD must justify the initiation of preliminary actions in the manner required by I-DE, in the sense that there must be something new or some new circumstance or that the complaints must have provided new and different circumstances regarding the documentation provided by I-DE in its notification of the breach to this Agency, as this is not required by the indicated regulation, in addition to the fact that it cannot be expected that the affected parties provide something new, aside from knowing that the confidentiality of their personal data has been violated by a cyberattack of which they are unaware of the circumstances.

Precisely, the preliminary investigative actions are carried out to clarify the facts and circumstances of what has occurred, gathering more information in order to determine whether or not there is a possible infringement of the data protection regulations. In this sense, the initiation of preliminary investigations and their execution, which is the power of the AEPD with or without complaints, does not prejudge anything, but allows for the collection of the necessary information to determine whether there are indications of an infringement or not. Even after such an investigation, it may be that the actions are archived because, based on the information gathered, it is understood that there are no indications of an infringement. This, in the present case, has not happened.

What the regulation does indicate is that, after the submission of complaints, this Agency must decide whether to admit them for processing or not, having ultimately decided to admit them through, this time, an Admission Agreement, signed by the Director of the Agency on May 9, 2022. And, as indicated by Article 67.2 of the LOPDGDD referenced, the AEPD may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances. It is a power that is attributed to it by the GDPR and by the LOPDGDD.

Furthermore, to elaborate on everything, even in the event that the complaints had not existed, the document from the Division of Technological Innovation would not have been an impediment or obstacle to the exercise of the investigative powers that the AEPD has in accordance with the aforementioned Article 64.2, which states that "Once the complaint is admitted for processing, as well as in cases where the Spanish Agency for Data Protection acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/88

Therefore, the present sanctioning procedure has not been initiated due to the content or any new information provided in the claims, but rather due to the information and documentation obtained after the preliminary investigation period, as possible violations of data protection regulations can be inferred from it.

Finally, I-DE brings to attention the Judgment of the Supreme Court, dated February 22, 2016 (appeal 4048/2013), understanding that it is fully applicable to the case, in which it is stated:

"In accordance with the facts briefly presented, we can consider legitimate trust to be violated, as the Administration cannot make decisions that contravene the perspectives and hopes based on its previous decisions. When there is reliance on the stability of its criteria, evidenced in multiple previous acts in the same direction, leading the administered party to make certain decisions, a trust based on the coherence of administrative behavior is generated, which cannot be disappointed by a surprising action. [...]"

It is important to note that legitimate trust ultimately requires the concurrence of three essential requirements. Namely, that it is based on undeniable and external signs (1); that the hopes generated in the administered party must be legitimate (2); and that the final conduct of the Administration is contradictory to previous acts, being surprising and incoherent (3).

This is exactly what occurs in the case examined, according to the facts previously narrated.

Let us remember that, regarding legitimate trust, we have repeatedly declared, among others, in the Judgment of December 22, 2010 (contentious-administrative appeal no. 257/2009), that “the principle of good faith protects the legitimate trust that may have been reasonably placed in the behavior of others and imposes the duty of coherence in one’s own behavior. This is tantamount to saying that the principle implies the requirement of a duty of behavior that consists of the necessity to observe, looking to the future, the conduct that previous acts made foreseeable and to accept the binding consequences that arise from one’s own acts, constituting a case of violation of the legitimate trust of the parties ‘venire contra factum proprium.’”

In this regard, it is noted that the doctrine established therein is not “applicable to the present case, since, as indicated earlier, it has neither been a decision of this Administration, nor by its form or content, nor has it led to trust in the stability of its criteria, as there has been no decisive criterion in this regard, much less evidenced in multiple previous acts in the same direction, so the action of this Agency concerning the allegations made has not constituted a final conduct of it that is contradictory to previous acts that is surprising or incoherent, in the sense of the doctrine of the Court.

For the reasons stated, the allegation made is dismissed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/88

THIRD.- ON THE ADDITIONAL AFFECTATION TO THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD

I-DE argues in this section that the Initiation Agreement incurs significant violations of the principles of sanctioning administrative law, as it implies the imposition of two infractions whose content is, in fact, identical or, at the very least, one can appreciate the subsumption of one in the other:

1. Violation of the principle non bis in idem

I-DE claims that in the Initiation Agreement, the AEPD considers that the security measures implemented by it have not been adequate, and that this implies a double violation of the GDPR. On one hand, it understands that I-DE has not adopted the appropriate technical and organizational measures required by Article 32 of the GDPR; and, on the other hand, it understands that the principle of security has been violated, allegedly breaching Article 5.1 f) of the GDPR, of which Article 32 is merely a specification.

I-DE understands that this means that two differentiated sanctions are imposed, respectively, for considering that my client lacks adequate security measures and because it understands that a breach of confidentiality of personal data has occurred due to the lack of such measures. Furthermore, it establishes for both alleged infractions identical modifying circumstances of I-DE’s liability, both in their determination and in the legal grounds for their imposition.

I-DE points out that it follows from this that the AEPD considers that a single fact (the alleged insufficiency of security measures) would constitute two infractions of the same protected legal good (the adequate guarantee of the rights and freedoms of the data subjects). This is because, on one hand, the absence of the security measures that the AEPD considers necessary to adopt would be sanctioned, and on the other hand, the principle of security and confidentiality, which requires the adoption of such measures, would also be sanctioned.

Therefore, I-DE argues that, incurring in the triple identity of subject, fact, and protected legal good, there is no doubt that the principle of non bis in idem has been violated, so that only one infraction can be attributed and sanctioned, which in this case would be solely under Article 32, as only the alleged insufficiency of security measures could be appreciated.

In response to this, it is necessary to explain the difference between the violation of Article 5.1.f and Article 32 of the GDPR, which will be expanded upon in the next point regarding the allegation related to the existence of medial concurrence, as well as the different typification in even distinct sections of Article 83 of the GDPR and the different qualification of both for the purposes of prescription in the LOPDGDD.

Article 5.1.f) of the GDPR is violated when there is a loss of confidentiality, integrity, or availability of

personal data due to the absence or deficiency of measures of any kind.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
30/88

This principle merely determines the channel through which the maintenance of confidentiality, integrity, or availability can be achieved, explicitly stating "through the application of appropriate technical and organizational measures," which are not strictly security measures.

I-DE indicates that the appropriate technical and organizational measures referred to in Article 5.1(f) of the GDPR are the security measures of Article 32 of the GDPR. This would simplify the essence of the GDPR, whose compliance is not limited to the implementation of technical and organizational security measures; it would mean, in our case, reducing the guarantee required by the principle of integrity and confidentiality to its achievement solely through security measures.

When Article 5.1(f) of the GDPR refers to appropriate technical or organizational measures to guarantee the rights and freedoms of data subjects within the framework of compliance management of the GDPR, it does so in the sense intended in Article 25 of the GDPR regarding privacy by design. This provision states that,

"Taking into account the state of the art, the cost of application, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of data subjects" (the underlining is ours).

It should be noted that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle. However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk. Security measures. Only security measures.

Furthermore, its objective is to ensure a level of security appropriate to the risk regardless of whether a security breach has occurred, while in the case of Article 5.1(f) of the GDPR, availability, confidentiality, and integrity must be guaranteed, which materializes, in this case, with the loss of confidentiality of the data. As can be observed, the two articles refer to different behaviors, although they may be related.

Delving into the examination of non bis in idem, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) states that,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
31/88

"(...) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same individual twice for the same act based on the same grounds, understood as the same legal interest protected by the relevant sanctioning norms. Indeed, when there is a triple identity of subject, act, and grounds, the accumulation of sanctions creates a penalty that is foreign to the proportionality assessment carried out by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

However, for there to be a discussion of "bis in idem," a triple identity must exist among the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

2.

The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority judging the case and irrespective of who the accuser or specific body that has resolved the matter is, or whether the case is judged alone or in conjunction with other affected parties.

b) The factual identity implies that the judged facts must be the same, and it excludes cases of real concurrence of infractions where there are not the same unlawful acts but several.

c) The identity of grounds or causal identity implies that the sanctioning measures cannot coexist if they respond to the same nature, that is, if they share the same teleological foundation, which occurs between penal and administrative sanctions, but not between punitive and merely coercive measures.” Taking into account the aforementioned, the principle of non bis in idem has not been violated, since, while broadly understood, the facts are detected as a consequence of a personal data breach, the infringement of Article 5.1(f) of the GDPR is specified in a clear loss of confidentiality and availability, while the infringement of Article 32 of the GDPR is reduced to the absence and deficiency of the security measures (only security) detected, which are present independently of the personal data breach. In fact, if those deficiencies in the security measures detected in the I-DE web application had been identified by the AEPD without the loss of confidentiality occurring, it would only have been possible to sanction it under Article 32 of the GDPR.

And all this in light of the allegations made by I-DE, which considers that both provisions require a single conduct, which is to implement adequate security. This is not true, since Article 5.1(f) of the GDPR is not limited to ensuring adequate security relative to the risk, but to ensuring integrity and availability through any measures. And not only through security measures, but through all kinds of appropriate technical or organizational measures.

As we have indicated, Article 5.1(f) of the GDPR sanctions a loss of availability and confidentiality, while Article 32 of the GDPR addresses the absence and/or deficiency of the security measures implemented by the data controller. Measures that are absent or deficient, we add, that infringe the C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/88

GDPR regardless of whether there has been a loss of confidentiality and availability.

Finally, regarding the application of identical aggravating factors in both infringements, we must indicate that the circumstances provided for in Article 83.2 of the GDPR and those set forth in Article 76.2 of the LOPDGDD are the only ones that can be applied by the AEPD for any infringement.

What is decisive in this case, concerning that provided for in Article 83.2.b) of the GDPR, is not that they coincide in their use, but rather the reasoning that is established for their consideration.

Having said all this, it is not considered that there is a violation of the principle of non bis in idem, enshrined in Article 25 of the Spanish Constitution.

2. Subsidiarily, existence of medial concurrence between the two behaviors attributed to I-DE

I-DE argues that, on the other hand, the Initiation Agreement identifies (and intends to sanction) a plurality of infringements that, supposedly, my client would have committed (which is categorically denied) when, in reality, one of them would be subsumed and embedded in the other, giving rise to a medial concurrence in the terms provided for in Article 29.5 of the LRJSP.

I-DE understands that both infringements cannot be sanctioned, given that the commission of the alleged infringement of Article 32.1 of the GDPR would determine the supposed violation of Article 5.1.f) of the same legal text and that it would be sanctioning for the same facts, as it considers that the alleged infringement of Article 5.1.f) would necessarily and inseparably arise from the alleged lack of diligent implementation of the measures referred to in Article 32.1 of the GDPR.

I-DE brings to attention certain jurisprudence (among others, Judgment 339/2015 of September 25, 2015, of the National Court - appeal 262/2014 - which cites the Judgment of the Supreme Court of February 8, 1999, - appeal 9/1996 -): “the application of medial concurrence requires a necessary derivation of some infringements with respect to others and vice versa, so it is essential that one

cannot be committed without executing the other.” Thus, there must be “such a relationship between the concerned infringements that one necessarily derives from the other, so that it is not possible to commit one without executing the other” (among others, Judgment of the National Court of December 26, 2013, - appeal 416/2012). Therefore, I-DE concludes that it is evident that such a relationship exists between the two infringements that are intended to be attributed to it.

In this regard, it is noted, as previously indicated, that Article 32 of the GDPR, although related to Article 5.1.f) of the GDPR, does not encompass the principle in its entirety.

Thus, Article 5.1.f) of the GDPR is one of the principles related to processing. The principles related to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/88

informing rules of the system with an intense expansive force; on the other hand, due to their high level of concreteness, they are mandatory rules that can be infringed.

Well, Article 5.1.f) of the GDPR incorporates the principle of integrity and confidentiality and stipulates that personal data shall be processed in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures of all kinds, not only security measures.

Furthermore, Article 32 of the GDPR regulates how security of processing should be articulated in relation to the specific security measures that must be implemented, in such a way that taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk that includes, among other issues, the ability to ensure the confidentiality of the data.

As noted, this provision, Article 32 of the GDPR, although related to Article 5.1.f) of the GDPR, does not encompass the principle in its entirety. Article 5.1.f) of the GDPR explicitly requires that confidentiality be guaranteed and requires a loss of confidentiality for its application. We may encounter situations where there are inadequate measures without a loss of integrity and confidentiality.

Evidence of this is not only the difference between the violation of Article 5.1.f and Article 32 of the GDPR but also the different typification in even distinct sections of Article 83 of the GDPR and the different qualification of both for the purposes of prescription in the LOPDGDD.

In the case examined, as stated in the proven facts, there is a clear loss of confidentiality evidenced by a clear result: there was unauthorized access by a third party to personal data.

Likewise, as indicated, Article 5.1.f) of the GDPR is violated when there is a loss of confidentiality, integrity, or availability of personal data, which may or may not occur due to the absence or deficiency of strictly security measures.

This principle merely determines the channel through which the maintenance of confidentiality, integrity, or availability can be achieved when it explicitly states "through the application of appropriate technical and organizational measures," which are not strictly security measures.

I-DE indicates that the appropriate technical and organizational measures referred to in Article 5.1.f) are the security measures of Article 32 of the GDPR. This would simplify the essence of the GDPR, whose compliance is not limited to the implementation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/88

of technical and organizational security measures; this would mean, in our case, reducing the required guarantee through the principle of integrity and confidentiality to its achievement solely with security measures.

As previously noted, when Article 5.1.f) of the GDPR refers to appropriate technical or organizational measures to ensure the rights and freedoms of data subjects within the framework of GDPR compliance management, it does so in the sense intended in Article 25 of the GDPR concerning privacy by design.

We reiterate that there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee this principle.

And all this in response to the allegations made to the contrary by I-DE, which considers that both provisions require a single behavior, which is to implement adequate security. This is not true, since Article 5.1.f) of the GDPR is not limited to ensuring adequate security relative to the risk, but to ensuring integrity and availability. And not only through security measures but through all kinds of appropriate technical or organizational measures.

As we have indicated, Article 5.1.f) of the GDPR penalizes a loss of availability and confidentiality, and Article 32 of the GDPR addresses the absence and inadequacy of the security measures implemented by the data controller. We add that absent or deficient security measures infringe the GDPR regardless of whether a loss of confidentiality and availability has occurred.

In this case, Article 32 has been infringed regardless of whether a breach of confidentiality has ultimately occurred or not, because the reproachable conduct that violates this provision is the lack or inadequacy of those measures in themselves, that is, it is infringed and sanctioned for this regardless of whether a personal data breach has occurred or not. This does not preclude that, in the event of a personal data breach materializing, this circumstance may be considered an aggravating factor, in accordance with the GDPR.

On the contrary, in this case, for us to be facing an infringement of Article 5.1.f), it has been and is an unavoidable requirement that the confidentiality of personal data is violated (which does not happen with the infringement of Article 32).

Regarding the medial concurrence, it should be noted that Article 29 of the LRJSP does not apply to the sanctioning regime imposed by the GDPR. This is because:

3.

The GDPR is a complete system.

The GDPR is a directly applicable community regulation in the Member States, which contains a new, complete, and global system aimed at ensuring the protection of personal data uniformly throughout the European Union.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/88

In relation, specifically and also, to the sanctioning regime established therein, its provisions apply immediately, directly, and integrally, providing a complete and gapless system that must be understood, interpreted, and integrated absolutely, fully, and integrally, thus leaving its ultimate purpose intact, which is the effective and real guarantee of the Fundamental Right to the Protection of Personal Data. The contrary results in a reduction of the guarantees of the rights and freedoms of citizens.

In fact, a specific example of the absence of gaps in the GDPR system is Article 83 of the GDPR, which determines the circumstances that may operate as aggravating or mitigating factors regarding an infringement (art. 83.2 of the GDPR) or specifies the existing rule concerning a possible concurrent offense (art. 83.3 of the GDPR).

To this, we must add that the GDPR does not allow the development or specification of its provisions by the legislators of the Member States, except for what the European legislator has specifically provided, delimiting it very concretely (for example, the provision of art. 83.7 of the GDPR). The

LOPDGDD only develops or specifies certain aspects of the GDPR to the extent that it allows and with the scope that it permits.

This is so because the purpose intended by the European legislator is to establish a uniform system throughout the European Union that guarantees the rights and freedoms of individuals, corrects behaviors contrary to the GDPR, promotes compliance, and enables the free movement of these data. In this regard, Recital 2 of the GDPR states that,

“(2) The principles and rules concerning the protection of natural persons with regard to the processing of their personal data must, irrespective of their nationality or residence, respect their fundamental freedoms and rights, in particular the right to the protection of personal data. This Regulation aims to contribute to the full realization of an area of freedom, security, and justice and of an economic union, to economic and social progress, to the strengthening and convergence of economies within the internal market, as well as to the well-being of natural persons.” (the underlining is ours)

Recital 13 of the GDPR further indicates that,

“(13) To ensure a consistent level of protection for natural persons throughout the Union and to avoid divergences that hinder the free movement of personal data within the internal market, a regulation is necessary that provides legal certainty and transparency to economic operators, including micro-enterprises and small and medium-sized enterprises, and offers natural persons in all Member States the same level of enforceable rights and obligations and responsibilities for controllers and processors, in order to ensure consistent supervision of personal data processing and equivalent sanctions across all Member States, as well as effective cooperation between the supervisory authorities of the different Member States. The proper functioning of the internal market requires that the free movement of data...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/88

personal data in the Union shall not be restricted or prohibited for reasons related to the protection of individuals with regard to the processing of personal data.” (the underlining is ours)

In this system, what is decisive in the GDPR are not the fines. The corrective powers of the supervisory authorities provided for in Article 58.2 of the GDPR, combined with the provisions of Article 83 of the GDPR, show the prevalence of corrective measures over fines.

Thus, Article 83.2 of the GDPR states that “Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those provided for in Article 58, paragraph 2, letters a) to h) and j).”

In this way, the corrective measures, which are all those provided for in Article 58.2 of the GDPR except for the fine, take precedence in this system, relegating the economic fine to cases where the circumstances of the specific case determine that a fine is imposed along with the corrective measures or in substitution of them.

And all this with the aim of enforcing compliance with the GDPR, preventing non-compliance, promoting compliance, and ensuring that the infringement is not more profitable than non-compliance. Therefore, Article 83.1 of the GDPR provides that “Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are in each individual case effective, proportionate, and dissuasive.” (the underlining is ours)

For this system to function with all its guarantees, it is necessary that several elements are deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case - or due to the application of a different media competition than that provided for in the GDPR, would undermine the effectiveness of the system, losing its meaning, its teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and

dissuasive. In this way, the interested parties would also be deprived of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is endowed with its own principle of proportionality that must be applied in its strict terms.

4.

There is no legal gap, there is no supplementary application of Article 29 of the GDPR.

In addition to what has been stated, it should be noted that there is no legal gap regarding the application of media competition. Neither the GDPR allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/88

There is also no subsidiary application of Article 29 of the GDPR. In Title VIII of the LOPDGDD relating to "Procedures in the event of a possible breach of data protection regulations," Article 63, which opens the Title, states that "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, insofar as they do not contradict them, subsidiarily by the general rules on administrative procedures." While there is a clear reference to the LPACAP, there is absolutely no subsidiary application regarding the LRJSP, which does not contain any provisions related to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided for in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap or subsidiary application of the same, nor can the section relating to medial competition be applied for the same reasons.

In any case, the judicial precedents cited by the claimant regarding medial competition stem from the application of the LOPD of 1999, which transposed Directive 95/46/EC, establishing a clearly different system under the GDPR. At that time, Article 115 of Royal Decree 1720/2007, of December 21, which approves the Regulation for the development of Organic Law 15/1999, of December 13, on the protection of personal data, did foresee a supplementary application of Law 30/1992, of November 26, on the Legal Regime of Public Administrations and the Common Administrative Procedure.

Thirdly, and focusing on the specific case examined, and without prejudice to the above, it should be emphasized that there is no medial competition. Article 29.5 of the LRJSP establishes that "When the commission of one infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed."

Well, medial competition occurs when, in a specific case, the commission of one infringement is a necessary means to commit another distinct one.

The established facts determine the commission of two distinct infringements, without the violation of Article 32 of the GDPR (security of processing), as asserted by the appellant, being the necessary means by which the infringement of Article 5.1.F) of the GDPR (principle of confidentiality) occurs.

In conclusion, from all of this and contrary to all that has been argued, it has been proven that I-DE was not diligent as it did not adequately guarantee the confidentiality of its customers' personal data, nor did it have the appropriate technical and organizational measures to ensure an adequate level of security.

For the reasons stated, the allegation is dismissed.

C/ Jorge Juan, 6

www.aepd.es

FOURTH.- ON THE ALLEGED BREACH BY I-DE OF ARTICLE 32 OF THE GDPR

I-DE claims to disagree with the statement in the Initiation Agreement that it was not sufficiently diligent in implementing appropriate security measures to prevent security incidents such as the one that occurred, as it argues that, as it has been demonstrating in its responses to the AEPD in the various requests for information, it has been proven that it had implemented multiple and robust security measures aimed at protecting its customers' information prior to March 2022.

I-DE then proceeds to detail the security measures it has implemented.

In contrast, it is noted that in the present case there was a vulnerability in the GEA web application, which was exploited by the cybercriminal. Thus, as has been established in the Established Facts and as indicated in Legal Basis VI of the Initiation Agreement, (...).

Therefore, the above demonstrates the existence of a web application with a vulnerability that allowed: (...)

Additionally, as a subsequent measure to prevent incidents like the one that occurred, I-DE modified the GEA application (...).

On the other hand, as existing security measures before the incident, they pointed out, among others, the following:

(...). And it is precisely this vulnerability that was exploited by the attacker during the security breach. (...)

From the above, it can be inferred that this attack could have been avoided if that code had not been visible. Even more so considering that this is one of the requirements set forth in the indicated document, (...).

Furthermore, this vulnerability is identifiable in security assessments. However, during the investigation proceedings, I-DE has not demonstrated that it detected the vulnerability of the GEA application within the framework of the security assessment program implemented in the Iberdrola Group. Moreover, as indicated, the last review or security assessment of critical applications dates back to 2019, almost two and a half years before the incident, so they were not being conducted very regularly considering the rapid advancements in technology, as well as the sophistication of cyberattacks, and no results obtained have been provided or explained.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
39/88

Therefore, the GEA application contained an avoidable and identifiable vulnerability that was exploited by the attacker. This clearly demonstrates a breach of Article 32 of the GDPR, as it requires appropriate measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing. (...)

Regarding the risks to the rights and freedoms based on which appropriate security measures must be established and applied, I-DE has not provided a risk analysis conducted prior to the incident that complies with Article 32 of the GDPR, as it does not indicate what measures should be applied at the level of risks. Furthermore, the approach of the risk analysis, contained in the Record of Processing Activities regarding the affected activity, is not oriented towards the risks that the loss of confidentiality, availability, or integrity may pose to the rights and freedoms of data subjects.

Recital 75 of the GDPR, cited in the Initiation Agreement, states that "Risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could

cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data concerning a person's sex life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects."

For its part, Article 28.2 of the LOPDGDD states that "In adopting the measures referred to in the previous paragraph, data controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

5. When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic, moral, or social harm to those affected."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/88

b) When the processing could deprive the affected individuals of their rights and freedoms or could prevent them from exercising control over their personal data (,,,"

As explained in the guide "Risk Management and Impact Assessment in Personal Data Processing" by the AEPD, "The GDPR establishes the obligation to manage the risk that processing poses to the rights and freedoms of individuals. This risk arises both from the very existence of the processing and from its technical and organizational dimensions. The risk arises from both the automated processing of data and its manual processing, from the human elements and from the resources involved. The risk arises from the purposes of the processing and its nature, as well as from its scope and the context in which it takes place."

However, these risks have not been assessed. The damages to individuals, whether material or immaterial, have not been evaluated, or at least it is not evidenced that this has been done, thus lacking a risk analysis focused on the protection of the rights and freedoms of the data subjects.

On the other hand, I-DE understands that the AEPD has linked the alleged non-compliance with Article 32 to the outcome that occurred as a result of the concurrence of a series of factors that were unpredictable and that were detected and resolved immediately. It therefore concludes that the AEPD is imposing, regarding the adoption of security measures, an obligation of result, whereas it is, in fact, an obligation of means.

In this regard, it brings to attention what was stated by the Supreme Court in its ruling of February 15, 2022 (cassation appeal 7359/2020), which clearly indicates that the obligation imposed by the personal data protection regulations to adopt technical and organizational measures aimed at ensuring the confidentiality, availability, and integrity of the information is an obligation of means and not of result.

In this respect, it should be noted that the aforementioned ruling indeed indicates, regarding security measures in the field of data protection, that "... the obligation that falls on the data controller and the data processor regarding the adoption of necessary measures to ensure the security of personal data is not an obligation of result but of means, and the infallibility of the measures adopted is not required. Only the adoption and implementation of technical and organizational measures, which according to the state of technology and in relation to the nature of the processing carried out and the personal data

in question, reasonably allow for the prevention of their alteration, loss, unauthorized processing, or access is required." (the emphasis is ours)

However, the ruling continues by indicating, in the specific case analyzed therein, that "... the program used for the collection of customer data did not contain any security measures that would allow verifying whether the email address entered was real or fictitious and whether it actually belonged to the person whose data was being processed and who was providing consent for it."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/88

The technology at the time these events occurred allowed for the establishment of measures aimed at verifying the authenticity of the email address, conditioning the continuation of the process on the user receiving the contract at the provided address and only from there granting the necessary consent for its collection and processing. Measures that were not adopted in this case.

(...) Thus, at the time these events occurred, there were technical measures related to the registration process that would have prevented the leakage of personal data that occurred. This implies that the technical measures adopted failed to meet the security conditions required under Article 9.1 of LO 15/1999, thereby incurring the infringement provided for in Article 44.3.h) consisting of "Maintaining files, premises, programs, or equipment that contain personal data without the necessary security conditions determined by regulation [...]".

Therefore, although it can be inferred from the Judgment that the obligations established by Article 32 of the GDPR are obligations of means, it is also clear that if, at the time of the incident, there were adequate technical measures in place to prevent or mitigate its effects and they were not applied, this constitutes a breach of the aforementioned obligation imposed by the GDPR and, consequently, an infringement thereof.

In the present case, as noted, there was a vulnerability in the GEA application, which was identifiable in security assessments as well as avoidable, as evidenced by the fact that I-DE subsequently took steps to correct this vulnerability. This clearly demonstrates a breach of Article 32 of the GDPR, as it requires appropriate measures to ensure a level of security appropriate to the risk, taking into account the state of the technology, the costs of implementation, and the nature, scope, context, and purposes of the processing.

I-DE also claims that the security breach was not caused by the insufficiency of the measures adopted, but rather by the intense activity carried out by a third party with the sole intention of executing the cyberattack to the detriment not only of I-DE's customers but of the company itself.

In response, it should be noted that total infallibility of the measures that can be adopted to ensure adequate protection in the processing of personal data has not been required. However, once the attack has occurred, the diligence of the data controller in applying appropriate technical and organizational measures to ensure a level of security appropriate to the risk must be assessed, taking into account the state of the technology, the costs of implementation, the nature, scope, context, and purposes of the processing.

In the present case, I-DE did not have adequate measures in place regarding the risks of processing for the protection of personal data at the time the data protection breach occurred, as indicated, there was a detectable and avoidable vulnerability in its web application, which was exploited by the cybercriminal.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/88

Finally, in accordance with the Judgment of June 22, 2021 - Rec. 1210/2018, and the Judgment of November 5, 2011 - Rec. 1796/2019, which assesses the subjective or culpability element, it is emphasized that the culpability of the plaintiff cannot be considered excluded or mitigated by the fact

that there was fraudulent action by a third party, since the responsibility of the plaintiff does not derive from the actions of this third party, but from their own actions.

Finally, I-DE points out that it had mechanisms in place that allowed for the almost immediate detection of the security breach suffered as a result of access to GEA, taking immediate action, which I-DE understands is a clear example of full compliance with the provisions of Article 32.1 c) of the GDPR, when it refers to "the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident," something that, however, has not been sufficiently valued by the Initiation Agreement.

In this regard, both in the Initiation Agreement and in the present proposal, it has been taken into account that I-DE reacted as quickly as possible and proceeded to take measures aimed at repelling the attack and preventing its recurrence, considering it as a mitigating factor in accordance with Article 83.2.c) of the GDPR.

For the reasons stated, the allegation made is dismissed.

FIFTH. – ON THE ALLEGED VIOLATION OF ART. 5.1.F) OF THE GDPR

In this section, I-DE argues that the fraudulent use of personal data has not been proven, not even indicatively, with the Initiation Agreement limiting itself to considering that there is a very high risk without it having materialized in practice.

In this regard, it is necessary to clarify that what is attributed to I-DE is the violation of the principle of confidentiality, as it is established that, after suffering a cyber attack against the GEA website, taking advantage of a vulnerability in it, there was an unauthorized access to personal data and the extraction of the same by an unauthorized third party, which resulted in the loss of confidentiality and control of numerous personal data (name and surname, ID number, postal address, fax, email, phone, customer code) affecting 1,350,000 customers of I-DE. This constitutes a breach of the duty to guarantee the confidentiality of personal data, as indicated, Article 5.1.f) states that they must be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing.

Regarding the high risk indicated that those data, in the hands of cybercriminal(s), could be used fraudulently, this was stated to express what the loss of confidentiality entails, but it is not necessary in any way, to understand that Article 5.1.f) has been infringed, for such risks of fraudulent use to materialize, because what has materialized with the breach is the loss of confidentiality of the personal data processed by I-DE, which is what is exclusively attributed to them.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/88

On the other hand, I-DE insists again in this section that it understands that the AEPD considered the breach reported by it to be archived and that the claims do not provide anything new, and therefore, nothing seems to justify the reopening of the investigation when it had already been archived.

In this regard, it is appropriate to refer to all that has already been argued in relation to this in Section Two of this Legal Basis.

For the reasons stated, the allegation made is dismissed.

SIXTH. – ON THE VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY

I-DE alleges that the sanctions imposed violate the principle of proportionality, as the AEPD, in determining the amount of the sanctions, has resorted to completely generic criteria.

Thus, regarding the alleged negligence in its actions, I-DE indicates that it has demonstrated that the events that occurred took place at a specific moment and were resolved very quickly, so the measures adopted in response to the incident mitigated its effects. This immediate resolution of the incident shows that they did indeed have planned actions in the event of a possible attack on their systems.

In contrast, it should be noted that the appropriate technical and organizational measures to ensure an adequate level of security against the risks that the processing of personal data may pose to the rights and freedoms of individuals cannot be merely reactive measures, that is, to immediately resolve a personal data breach. Thus, Article 32 of the GDPR not only indicates that adequate security must be

ensured but also that such measures must include the ability to guarantee the confidentiality, integrity, availability, and permanent resilience of the processing systems and services (letter b of Article 32.1 GDPR). Therefore, it is not enough to have measures to react as quickly as possible when confidentiality has been breached; there must also be adequate preventive measures in place to prevent such a breach. This is because measures aimed at safeguarding the confidentiality, integrity, and availability of personal data, that is, preventive measures aimed at avoiding any breach of these, are equally or more important.

Therefore, it cannot be accepted that the measures implemented by I-DE were adequate because they allowed for the resolution of the incident afterward, as this only demonstrates the existence of corrective measures. However, what those reactive measures allowed was the cessation of the attack once it had occurred and the restoration of the service; that is, regarding the protection of personal data, it prevented a greater impact, and this has already been taken into account as a mitigating factor in the present sanctioning procedure, but in no way can they remedy the loss of confidentiality of the affected personal data, as this had already materialized.

That is to say, the confidentiality of personal data is primarily guaranteed by preventive measures. In this regard, it has already been indicated in the response to Allegation Four of this Legal Basis the vulnerability contained in the GEA application, which was exploited by the cybercriminal for their attack and which was also perfectly identifiable in security assessments. In relation to this last point, it should not be forgotten that Article 32.2 GDPR stipulates that security measures must also include a process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of processing.

Therefore, all of this merely reflects a lack of diligence on the part of I-DE in ensuring adequate security against the risks of the data processing it carries out. In this sense, it should not be forgotten that GEA is a web application, that is, it allows access from the internet to a database where personal data of millions of customers are stored, which constitutes large-scale processing, requiring adequate security measures for that web environment and specifically aimed at ensuring that there is no unauthorized access to such personal data.

On the other hand, I-DE states that it does not agree with the consideration of its activity's connection to the processing of personal data as an aggravating factor, as it believes that its conduct is being aggravated by belonging to the electricity sector and that therefore it should be required to exercise special diligence, which again violates the principle of proportionality.

In contrast, it is emphasized that its conduct is not aggravated by belonging to the electricity sector, but rather because its activity, the development of its business, involves and requires continuous and extensive processing of personal data, as evidenced by the fact that it processes data of millions of people.

Therefore, as indicated in the Initiation Agreement, I-DE is a company accustomed to processing personal data, which again entails the requirement for a higher degree of diligence.

On the other hand, it is noted that Article 83.2 of the GDPR provides that "When deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

(...)

k) any other aggravating or mitigating factor applicable to the circumstances of the case..."

In this regard, the Spanish legislator has considered including in Article 76 of the LOPDGDD that: "2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

(...)

b) The connection of the infringer's activity with the processing of personal data."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/88

This Agency simply takes into consideration that circumstance, provided for by the legislator, when

deciding on the imposition of the administrative fine. It is worth noting that, for the purposes of deciding on the imposition of an administrative fine, an infringement committed by a natural person or a small company unaccustomed to the processing of personal data cannot be given the same consideration as that of a large company like I-DE, which is accustomed to processing personal data of millions of clients and has a long track record in this regard. Of course, it is considered that the infringement is more serious for the purposes of imposing a fine if the data controller falls into the latter category, as is the case with I-DE.

On the other hand, it argues the lack of proportionality by comparing it with file PS/00179/2020, in which it indicates that it was only fined 500,000 euros despite the fact that not only was confidentiality breached, but the breach was not reported to the AEPD, which I-DE did do; however, the penalty is considerably lower.

In this regard, it should be noted, on the one hand, that in matters of data protection, the technical and organizational security measures to be adopted by data controllers and other obligations required by the GDPR must be appropriate in relation to the specific risks posed by the specific processing carried out by each controller. Therefore, when analyzing the diligence of each party in complying with the regulations, the circumstances of each case must be taken into account, considering the nature, scope, context, and purposes of each processing, meaning that there are no identical cases.

On the other hand, Article 83 establishes that

1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed based on the circumstances of each individual case...”

Therefore, the circumstances of each individual case must be taken into account, as there are no two identical files and, consequently, no identical outcomes. For example, in the file that is brought up, the affected parties were less than half of those in the case at hand; the infringement of Article 32 of the GDPR was due to another type of insufficiency in the measures to ensure adequate security for the processing; the events occurred in 2018, the year in which the GDPR began to be mandatorily applicable, which is not the same as four years later; the knowledge of the technique is not the same a few years before and after, especially due to its rapid advancement, etc.

It is also noted that there are many other files, both subsequent and prior to the present one, in which high fines have been imposed for both breaches of data confidentiality and infringements of security measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

46/88

Article 32 of the GDPR, although, as noted, must always take into account the specific circumstances of the case.

Finally, and to further elaborate, it is not appropriate to demand equality in illegality. The jurisprudence is clear on this matter. Thus, the Judgment of the National Court of April 28, 2023 (SAN 28.04.2023 REC. 409/2021) indicates that “A discriminatory sanctioning treatment is referred to since that fine or economic sanction can be replaced by the measures of Article 58 GDPR, less burdensome measures such as a warning. It refers to other infringements committed by other entities. Of course, the plaintiff tries to compare this situation with another sanctioning procedure that is mentioned, but we are not facing a discriminatory treatment or a violation of the principle of equality since it is a principle that only operates within the framework of legality when identical factual situations are treated differently without reasonable justification. As stated in the STS of January 20, 2004, “equality must be asserted within legality, so if the correct action of the Administration is the one now being judged, as we have declared, the one invoked as contrary to it was not, and therefore, it cannot be argued to apply equal treatment to the appellant, since, as this Chamber of the Supreme Court has declared in its judgments of June 16, 2003, July 14, 2003, and October 20, 2003, “the principle of equality lacks significance to protect a situation contrary to the legal order,” and this, as indicated by the sentencing Chamber itself,

regardless of the fact that the alleged administrative action as contradictory to the present has not been proven.”

In the same vein, the STS of April 2, 2014 (Rec. 1916/2010) states that “legality prevails over a possible violation of the principle of equality.” In this case, we are faced with an administrative infringement that is intended to be compared with another that has had a different solution, but from what is observed in the allegation made by the plaintiff, it is hardly possible to make a comparison between one situation and another. Let us remember that according to the consolidated constitutional doctrine, to appreciate the concurrence of a violation of the principle of equality, the following prerequisites must be met: 1) provision of an appropriate term of comparison demonstrating the substantial identity of the legal situations that have received different treatment, 2) that the unequal treatment is not based on objective reasons that justify it, and 3) that the comparative judgment is developed within the framework of legality, since the principle of equality cannot be invoked in illegality to perpetuate situations contrary to what is provided by the legal order. Given these circumstances, the conduct for which the plaintiff has been sanctioned and which is contrary to law does not allow for their responsibility to be mitigated by the fact that in other cases, which are unknown, the imposed sanction was not economic and was considered more beneficial.”

For all the above reasons, the allegation made is dismissed.

V

Response to the allegations regarding the Proposal for Resolution

In response to the allegations presented by I-DE, the following should be noted:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/88

FIRST: On the defenselessness generated for I-DE as a consequence of the failure to agree on the accumulation of procedures EXP202305587 and EXP202205206

I-DE reaffirms its position regarding the Initiation Agreement concerning its request for the accumulation of both files, indicating that, regardless of the fact that Article 57 of the LPACAP states "may," the power granted must be considered enforceable by the Administration when the non-accumulated processing of the procedures may negatively affect the rights of the parties involved, insisting that the lack of accumulation infringes upon its right to defense.

Thus, it indicates that the administrative file does not even contain the actual accreditation of the admission for processing of any claim directed against I-DE or any other company of the Iberdrola Group, such that I-DE has been forced to infer, based on the Investigation Actions Report (IAI), the information that could have led to the opening of the present sanctioning procedure by the AEPD. For this reason, I-DE understands that this simple fact would be sufficient to justify the obligation to accumulate the two files, as its access to the information that the AEPD has deemed necessary to consider two alleged violations of data protection regulations has been limited to those elements that the AEPD has considered appropriate to incorporate into the present file, without being able to have a complete view of the facts or, consequently, of the reasons that lead the AEPD to impose such sanctions. Therefore, I-DE considers that the non-accumulation of the procedures harms its rights. In this regard, it should be noted, first of all, that a response was already provided in the resolution proposal regarding the request for the accumulation of the two referenced files, a response that is transcribed in Legal Basis III of this Resolution to which reference should be made. Therefore, while it is true that it is a power of the Administration to proceed with the accumulation or not, it is also true that the reasons and arguments were provided as to why it was not appropriate to accumulate both sanctioning procedures.

Regarding what I-DE has alleged about the non-accumulation causing defenselessness because its file does not contain the admission for processing of any claim against it, it should be noted that such admissions for processing are also not present in the other file to which it requests accumulation, so it would have no effect in this regard, consequently not causing any defenselessness due to the non-accumulation.

In this regard, it is noted that, since April 2, 2022, claims from clients affected by the security incident have been submitted to this Agency, which have been progressively admitted for processing since May 9, 2022. In this sense, it is indicated that the claimants basically claim to have seen their personal data affected by the aforementioned breach, without being able to provide any additional information since, logically, in the face of cyberattacks like the one suffered, they can provide little or no information due to their lack of knowledge and access to it. These claims were successively admitted for processing, starting from May 9, by the Director of this Agency, as they were submitted since April.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/88

2022. None of these have been subject to any further proceedings. This is why these claims do not form part of the present sanctioning procedure, only two to which I-DE has had access, and therefore no defenselessness has been caused.

Furthermore, in the Background sections of both the Initiation Agreement and the Proposal for Resolution, as well as in this Resolution, the existence of these claims has been indicated. Specifically, it is stated in Background Fifth that “Since April 2, 2022, claims from clients affected by the security incident have been submitted to this Agency, which have been progressively admitted for processing since May 9, 2022.” Therefore, I-DE has been informed from the beginning of the existence of these claims.

For the reasons stated, the knowledge or lack thereof of the specific content of these claims does not affect I-DE's right to defense in any way, as the present sanctioning procedure was initiated and has been processed solely as a consequence of the proven facts arising from the preliminary investigation actions carried out by this Agency. Therefore, I-DE has been fully aware at all times of the facts attributed to it and all circumstances related to them, which, it is emphasized, derive exclusively from all the documentation collected and other actions carried out during the preliminary investigations and not from the content of the claims that do not form part of either of the two procedures. Likewise, it has been aware at all times of the infringements attributed to it for such facts and of the sanctions that may arise from them, and it has been able to allege and present any documentation it deemed pertinent throughout the present sanctioning procedure.

Therefore, the requested non-accumulation does not cause it any defenselessness nor does it negatively affect any of its procedural rights.

Regarding the rest of the arguments raised by I-DE to demand the accumulation, as these are a reproduction of those presented against the Initiation Agreement, it is appropriate to refer to the response given by this Agency, which appears, as noted, transcribed in Legal Basis III of this Resolution.

SECOND: Regarding the prior acts of the AEPD and the violation of the principles of good faith, legitimate trust, and legal certainty.

I-DE insists again that the letter dated April 18, 2022, addressed to it from the Division of Technological Innovation of this Agency has a decisive nature and that this prevents or should have prevented any subsequent investigative action regarding the personal data breach suffered, which also violates the principles of good faith, legitimate trust, and legal certainty.

It also indicates that one of the functions of the Division of Technological Innovation of this Agency is to “analyze and classify security breaches and, where appropriate, propose to the Presidency the initiation of an investigation when it perceives indications of the commission of an infringement” (Article 31 e) of the Statute of the AEPD).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/88

I-DE adds that the aforementioned document is signed by the "AEPD," which implies that it should be understood as signed by the Director, since the "legal and institutional representation" of the Agency corresponds solely and exclusively to the Director, as established in Article 13.1b) of the AEPD Statute.

From this, I-DE concludes that, having analyzed the information communicated by it regarding the security breach, the Division of Technological Innovation understood that it was not appropriate to elevate any type of motivated proposal to the Director of the AEPD in relation to the same, as it did not consider that the provisions of the GDPR had been infringed. This resulted in the Agency being notified of the decision not to carry out any action related to the aforementioned breach.

In this regard, it is first necessary to recall that this issue was already addressed in the Proposal for Resolution, a response that is fully transcribed in Legal Basis IV of this Resolution and to which reference should be made.

On the other hand, it cannot be accepted or understood, even indirectly, that the aforementioned document in question is signed by the Director of this Agency, as her signature does not appear expressly, no matter how much I-DE wants to artificially presume that the signature comes from that body by holding the representation of the AEPD. No generic signature of the AEPD or any of the bodies in which it is structured, nor the signature of any of the individuals holding them, can replace the signature of the Director when exercising the competencies attributed to her both by Law and by the AEPD Statute. The delegation of signature in these cases must be direct and express, and must be recorded in the administrative act that is signed by delegation to ensure and safeguard that the decision has been adopted by a competent body.

In this sense, the Statute of the Spanish Agency for Data Protection, approved by Royal Decree 389/2021, of June 1 (hereinafter the Statute), expressly establishes that:

1. It is the responsibility of the Presidency of the Spanish Agency for Data Protection:

d) To issue the resolutions and guidelines required for the exercise of the Agency's functions, particularly those arising from the exercise of the competencies provided for in Article 57 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and from the exercise of the investigative powers and corrective powers provided for in Article 58 of the aforementioned Regulation. (the underlining is ours)

On the other hand, Article 27 of the Statute establishes the competencies of the General Subdirectorate for Data Inspection of the AEPD:

1. The General Subdirectorate for Data Inspection is the administrative body, dependent on the Presidency of the Spanish Agency for Data Protection, that develops the competencies provided for in Article 57.1, letters f), g), h), i), and u) of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, and carries out the inspection and instruction functions necessary for the exercise of the investigative powers established in Article 58.1, letters a), b), d), e), and f).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/88

and the corrective powers provided for in Article 58.2, letters a), b), c), d), f), g), i) and j), both of the aforementioned Regulation. (the underlining is ours)

2. In order to fulfill the tasks established in the previous section, the General Subdirectorate of Data Inspection has the following functions:

a) The ongoing supervision of compliance with Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, of Organic Law 3/2018, of December 5, and of the provisions that develop it, by the data controllers and processors.

b) The exercise of the investigative powers defined in Article 51 of Organic Law 3/2018, of December 5.

(...)

d) The processing of procedures in the event of a possible violation of data protection regulations in accordance with the provisions of Title VIII of Organic Law 3/2018, of December 5, including citizens'

complaints for lack of attention to their requests for the exercise of the rights contemplated in Articles 15 to 22 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016. It is the responsibility of the General Subdirectorate of Data Inspection to inform the complainant about the course and the outcome of the complaint submitted to the Spanish Agency for Data Protection, in accordance with the provisions of Article 77.2 of the aforementioned Regulation.

(...)

e) The evaluation of the admissibility of the complaints submitted to the Spanish Agency for Data Protection, and the proposal to the Presidency of a decision on the admission or inadmissibility of the complaint, in accordance with the provisions of Article 65 of Organic Law 3/2018, of December 5.

(...)

h) The carrying out of preliminary investigative actions agreed upon by the Presidency on its own initiative, following a complaint, or at the request of another body or control authority, in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure, as provided for in Article 67 of Organic Law 3/2018, of December 5. (the underlining is ours)

Therefore, regarding the Division of Technological Innovation of the AEPD, which in accordance with the Statute has, among its functions, the task of "analyzing and classifying security breaches and, where appropriate, proposing to the Presidency the initiation of an investigation when it perceives indications of the commission of an infringement" (Article 31 e) of the AEPD Statute), this does not mean that it is the only and exclusive way through which this Agency can initiate investigative actions. Thus, this investigative power that the AEPD has, as reflected in the described regulations, is carried out by the General Subdirectorate of Data Inspection, which can initiate investigative actions either ex officio, by order of the Director, or as a result of the admission of complaints submitted to the AEPD.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/88

The Division of Technological Innovation, after analyzing the documentation provided by I-DE (which does not cover all the circumstances of the incident), has indicated that it does not foresee the initiation of other actions, and it does not mean that it considers the provisions of the GDPR to have been infringed or that a decision has been made not to carry out any actions related to the aforementioned breach. The Division of Technological Innovation did not make a decision; it merely informed I-DE of a forecast, which does not prevent other circumstances from being taken into account, such as the filing of complaints by those affected by the breach, which may advise deviating from this forecast.

Therefore, the aforementioned document does not have the decisive and resolute character that I-DE intends, neither by its content nor by its form, and this does not hinder nor can it in any way prevent the investigative authority that the AEPD possesses and its exercise through the inspection and investigation functions assigned to the General Subdirectorate of Data Inspection. Above all, following the filing of complaints by affected individuals, which the LOPDGDD requires to be processed.

Thus, Article 65 of the LOPDGDD, relating to the "Admission of complaints for processing," establishes that:

1. When a complaint is presented to the Spanish Agency for Data Protection, it must evaluate its admissibility for processing, in accordance with the provisions of this article.

2. The Spanish Agency for Data Protection will inadmit complaints presented when they do not relate to issues of personal data protection, are manifestly unfounded, are abusive, or do not provide reasonable indications of the existence of an infringement.

Therefore, once complaints are filed with the AEPD, it is obliged to analyze their admissibility beforehand, being able to inadmit them only in the cases specified in section 2 of Article 65 transcribed, which were not present in the case at hand.

Thus, once admitted for processing, preliminary investigation actions were initiated precisely to ascertain the facts and circumstances that occurred and whether a possible violation of data protection regulations could be derived from them, as permitted and empowered by Articles 64 and 66 of the

LOPDGDD, which were already transcribed in the response to the allegations to the Initiation Agreement and which, for the sake of clarity, are reiterated:

Article 64. Method of initiation of the procedure and duration.

1. When the procedure refers exclusively to the lack of attention to a request for the exercise of the rights established in Articles 15 to 22 of Regulation (EU) 2016/679, it will be initiated by an agreement of admission for processing, which will be adopted in accordance with the provisions of Article 65 of this organic law.

In this case, the deadline for resolving the procedure will be six months from the date on which the agreement of admission was notified to the complainant.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/88

admission to processing. After this period, the interested party may consider their claim accepted.

2. When the procedure aims to determine the possible existence of an infringement of the provisions of Regulation (EU) 2016/679 and this organic law, it will be initiated by an initiation agreement adopted on its own initiative or as a result of a claim.

If the procedure is based on a claim made to the Spanish Data Protection Agency, prior to this, it will decide on its admission to processing, in accordance with the provisions of Article 65 of this organic law.

When the rules established in Article 60 of Regulation (EU) 2016/679 apply, the procedure will be initiated by the adoption of the draft initiation agreement for sanctioning procedures, of which formal notice will be given to the interested party for the purposes provided in Article 75 of this organic law. Once the claim is admitted for processing, as well as in cases where the Spanish Data Protection Agency acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions, which will be governed by the provisions of Article 67 of this organic law.

Article 67. Preliminary Investigative Actions.

1. Before the adoption of the initiation agreement for the procedure, and once the claim has been admitted for processing if there is one, the Spanish Data Protection Agency may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure.

The Spanish Data Protection Agency will act in any case when it is necessary to investigate treatments that involve massive traffic of personal data.

2. The preliminary investigative actions will be subject to the provisions of Section 2 of Chapter I of Title VII of this organic law and may not exceed a duration of twelve months from the date of the admission agreement for processing or from the date of the agreement deciding its initiation when the Spanish Data Protection Agency acts on its own initiative or as a result of the communication that has been sent to it by the supervisory authority of another Member State of the European Union, in accordance with Article 64.3 of this organic law. (the underlining is ours)

Therefore, it is reiterated that from this regulation it is not inferred in any way that the AEPD must justify in the manner required by I-DE the initiation of preliminary actions in the sense that there must be something new or some new circumstance or that the claims must have provided new and different circumstances regarding the documentation provided by I-DE in its notification of the breach to this Agency, as this is not required by the indicated regulation, in addition to the fact that it cannot be...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/88

to expect that those affected provide something new, aside from knowing that their personal data confidentiality has been breached due to a cyberattack, the circumstances of which they are unaware. The preliminary investigative actions are precisely carried out to clarify the facts and circumstances of

what has occurred, gathering more information in order to determine whether or not there is a possible infringement of data protection regulations. In this regard, the initiation of preliminary investigations and their execution, which is the authority of the AEPD with or without complaints, does not prejudge anything; rather, it allows for the collection of the necessary information to determine whether there are indications of an infringement or not. Even after such an investigation, it may be that the proceedings are archived because, based on the information gathered, it is understood that there are no indications of an infringement. This, however, has not happened in the present case.

What the reflected regulations indicate is that, after the submission of complaints, this Agency must decide whether to admit them for processing or not, having ultimately decided to admit them through, this time, an Agreement of admission for processing, signed by the Director of the Agency on May 9, 2022. And, as indicated in Article 67.2 of the LOPDGDD referenced, the AEPD may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances. This is a power attributed to it by the GDPR and the LOPDGDD.

Furthermore, and to elaborate further on everything, as indicated, even in the event that there had been no complaints, the provision of the Division of Technological Innovation would not have been an obstacle or impediment for the exercise, ex officio, of the investigative powers that the AEPD has in accordance with the aforementioned Article 64.2, which states that "Once the complaint is admitted for processing, as well as in cases where the Spanish Data Protection Agency acts on its own initiative, prior to the initiation agreement, there may be a phase of preliminary investigative actions..."

Therefore, the present sanctioning procedure has not been initiated due to the content or any new information provided in the complaints, but rather due to the information and documentation obtained after the preliminary investigative actions, from which possible violations of data protection regulations can be inferred.

THIRD: Regarding the arguments put forward by the Resolution Proposal to consider that the principle of non bis in idem does not apply.

I-DE again indicates that the principle of non bis in idem has been violated in the imposition of the two infringements, as it understands that the AEPD is not judging the violation of Article 5.1.f) of the GDPR for a reason different from that derived from what it considers to be inadequate security of personal data, but solely and exclusively for that reason.

In this regard, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) was already pointed out, which states,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
54/88

"(...) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same individual twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the accumulation of sanctions creates a penalty that is foreign to the proportionality assessment carried out by the legislator and materializes the imposition of a sanction not legally provided for, which also violates the principle of proportionality.

However, for "bis in idem" to be applicable, a triple identity must exist among the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

- a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority judging the case and irrespective of who the accuser or specific body that has resolved the matter is, or whether it is judged alone or in conjunction with other affected parties.
- b) The factual identity implies that the judged facts must be the same, and excludes cases of real concurrence of infractions where there are not the same unlawful act but several.
- c) The identity of grounds or causal identity implies that the sanctioning measures cannot coincide if they respond to the same nature, that is, if they share the same teleological foundation, which occurs

between penal and administrative sanctions, but not between punitive and merely coercive measures.” Taking into account the aforementioned, in the sanctioning procedure, the principle of non bis in idem has not been violated, since, although broadly understood, the facts are detected as a consequence of a personal data breach, the infringement of Article 5.1.f) of the GDPR is specified in a clear loss of confidentiality that affected certain clients, while the infringement of Article 32 of the GDPR is reduced to the deficiency of the security measures (only security) detected, which are present independently of the personal data breach. In fact, if these security measures that I-DE had implemented had been detected by the AEPD without the loss of confidentiality occurring, it would have only been sanctioned under Article 32 of the GDPR.

As we have indicated, Article 5.1.f) of the GDPR sanctions a loss of confidentiality and availability, while Article 32 of the GDPR addresses the deficiency of the security measures implemented by the data controller. We add that deficient security measures violate the GDPR, regardless of whether or not a personal data breach has occurred.

Article 32 of the GDPR is violated regardless of whether or not a personal data breach occurs. That is to say, it is infringed by not having appropriate measures to ensure adequate security in the processing of data, without it being necessary or essential for a personal data security breach to occur that, in its case, may affect the confidentiality of the data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/88

data, whether only to availability, or only to integrity, or to some or all of them.

Another matter is that the deficiency in security measures is manifested, in the specific case, during a violation of the security of personal data (breach of confidentiality in this case), as has occurred in the present case.

On the other hand, Article 5.1(f) of the GDPR is violated when there is a loss of confidentiality or integrity of personal data, which may or may not occur due to the absence or deficiency of security measures. This principle merely determines the pathway through which the maintenance of confidentiality, integrity, or availability can be achieved when it explicitly states "through the application of appropriate technical and organizational measures," which are not strictly security measures. It is also emphasized again that Article 5.1(f) of the GDPR is one of the principles related to processing. The principles related to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with an intense expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

The breach of confidentiality attributed to I-DE is due to failing to comply with the obligation imposed in Article 5.1(f) to process data in such a way that an adequate level of security is guaranteed, including protection against unauthorized or unlawful processing, through the application of appropriate technical or organizational measures.

Finally, it should be added that, regarding the alleged violation of the principle of non bis in idem, a response to this allegation was already provided in the Proposal for Resolution, where it is extensively argued that the triple identity of facts, subject, and basis, as required by jurisprudence, does not exist, a response that is fully transcribed in section Third of the Legal Basis IV of this Resolution and to which reference should be made.

Lastly, concerning what I-DE has alleged regarding the imputation of the infringement of Article 5.1(f), claiming that a result obligation is being demanded, which is contrary to the Judgment of February 15, 2022 (cassation appeal 7359/2020), which states that the obligation imposed by personal data protection regulations to adopt technical and organizational measures is an obligation of means and not of results, it is noted that what was analyzed in that Judgment is the compliance with technical and organizational measures in the sense of whether they are adequate to ensure the security of the processing, that is, we would not be in the realm of compliance with Article 5.1(f), but in the realm of

compliance with Article 32 of the GDPR as it concerns security measures. Therefore, the argument presented by I-DE and the analysis thereof that will be conducted must exclusively refer to the infringement of Article 32 of the GDPR, which will be developed in section Fifth of this Legal Basis concerning the infringement of Article 32.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
56/88

FOURTH: Regarding the application of the principles of sanctioning law to the activity of the AEPD and the concurrence of a medial contest.

I-DE again argues that, in the event that the existence of bis in idem is not recognized, at least one of the infringements would be subsumed and embedded in the other, since the imputation of the infringement of Article 5.1.f) of the GDPR is due to the fact that the processing has not been carried out, in the opinion of the AEPD, in compliance with the necessary security measures. I-DE therefore understands that there is an absolute linkage between the alleged absence of adequate security measures and the breach of the principle of confidentiality. That is to say, it is the alleged insufficiency of the security measures that directly leads to the violation of Article 32 and the violation of Article 5.1.f).

Thus, there is a clear case of medial contest, as the two infringements attributed cannot be committed one without the other.

Next, I-DE argues the reasons why it considers that Article 29 of the LRJSP is applicable and that, by not applying it, the AEPD is implicitly repealing, in matters of data protection, all the guarantees of the sanctioning regime established by the Constitutional Court.

In this regard, since this allegation was already made against the Initiation Agreement and was extensively addressed in the Proposal for Resolution, which is fully transcribed in section Third of Legal Basis IV, it is appropriate to refer to it in its entirety.

On the other hand, regarding the mention made by the AEPD concerning the non-applicability of Article 29 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (hereinafter, "LRJSP"), I-DE brings up Royal Decree 389/2021, of June 1, which approves the Statute of the Spanish Agency for Data Protection, in which Article 3 establishes that the AEPD is governed by the provisions of the GDPR, and subsidiarily, by the LRJSP. I-DE understands that the above implies that, in relation to everything not expressly regulated in the GDPR or the LOPDGDD, the provisions in the LRJSP will apply, as is the case with the contests of infringements provided for in Article 29 of the LRJSP in relation to the principle of proportionality as a principle of the sanctioning power.

In this regard, it is noted that Article 3.2 of the aforementioned Statute of the AEPD establishes the following:

2. Subsidiarily, as far as it is compatible with its full independence, it will be governed by Law 40/2015, of October 1, on the Legal Regime of the Public Sector, in particular the provisions for autonomous bodies; by Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations; by Law 47/2003, of November 26, on General Budgetary Matters; by Law 9/2017, of November 8, on Public Sector Contracts, by which the Directives of the European Parliament and of the Council 2014/23/EU and 2014/24/EU, of February 26, 2014, are transposed into the Spanish legal system; by Law 33/2003, of November 3, on the Heritage of Public Administrations, as well as the rest of the regulations.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
57/88

of general and special administrative law that is applicable. In the absence of an administrative norm, common law shall apply.

Therefore, what is being indicated is that the legal regime of the Public Sector applies subsidiarily, but

regarding its consideration as a public body belonging to the General Administration of the State, that is, to considerations such as its composition, organization, structure, etc.

On its part, Article 3.3 of the Statute of the AEPD states the following:

3. The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily by the general norms on administrative procedures.

Therefore, in the procedures processed by it, including the sanctioning procedure, neither the LRJSP nor the LPAC applies subsidiarily, but it declares that the procedures processed by the AEPD shall be governed by the RGPD and the LOPDGDD. And subsidiarily (not supplanted) by the norms on administrative procedures.

In this regard, it is emphasized that there is no supplementary application of the aforementioned provision, since there is no legal gap regarding the application of the medial competition provided for in Article 29 of the LRJSP. Neither the RGPD allows nor the LOPDGDD provides for the supplementary application of the provisions of Article 29 of the LRJSP.

In Title VIII of the LOPDGDD relating to "Procedures in the event of a possible violation of data protection regulations," Article 63 that opens the Title states that "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, in this organic law, by the regulatory provisions issued in its development and, insofar as they do not contradict them, subsidiarily by the general norms on administrative procedures." Although there is a reference to the LPACAP, there is absolutely no establishment of a subsidiary application regarding the LRJSP, which does not contain any provision in its wording relating to any administrative procedure.

In the same way that the AEPD is not applying the aggravating and mitigating factors provided for in the same Article 29 of the LRJSP, since the RGPD establishes its own, therefore, there is no legal gap or subsidiary application of the same, nor can the section relating to medial competition be applied for identical reasons.

As already indicated, the application of rules foreign to the RGPD regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the RGPD - or in the LOPDGDD in the Spanish case - or due to the application of a medial competition different from that provided in the RGPD, would undermine the effectiveness of the system, which would lose its meaning, its teleological purpose, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and deterrent. And in this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the RGPD. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the RGPD.

To clarify, it should be noted that subsidiarity refers to cases in which a specific situation is not regulated in a given norm, a legal gap, leading to the application of another legal norm that regulates such a situation, provided that it does not conflict with the legal system.

While subsidiarity refers to a competition of norms, which means that for a given situation, two or more norms may be applicable, so that the subsidiary norm yields in favor of the principal one.

Well, having examined both subsidiarity and supplementary application, it is concluded that Article 29 of the LRJSP does not apply, but rather Article 83 of the RGPD in relation to the principle of proportionality.

This is so because:

- The principle of proportionality applies to the sanctioning procedure.
- The principle of proportionality is fully regulated in Article 83 of the RGPD.
- There is no legal gap.
- Neither the RGPD nor the LOPDGDD refer to the application, due to the existence of a legal gap, of Article 29 of the LRJSP.
- In the procedures processed by the AEPD, for the administrative procedures processed, the subsidiary application of the general norms on administrative procedures is provided.

- In the procedures processed by the AEPD, for the administrative procedures processed and not in relation to the principles of the sanctioning procedure, the LOPDGDD does not establish a subsidiary application of the LRJSP.

Therefore, there is neither subsidiarity nor supplementary application that would make Article 29 of the LRJSP applicable.

Regarding the fact that, as indicated by I-DE, the Agency itself has previously considered the applicability of said Article 29 considering the existence of cases of medial competition, as in its Resolution of April 23, 2021, issued in procedure PS/00240/2019, it should be noted that the Administration can depart from what was resolved previously. Thus, Article 35 of the LPACAP establishes that:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
59/88

1. They shall be motivated, with a succinct reference to facts and legal grounds:

c) The acts that deviate from the criteria followed in previous proceedings or from the opinions of advisory bodies.

Therefore, it is legitimate for the Administration to depart from the criteria followed in previous proceedings, provided that such change is justified, which is the case here. Thus, in addition to what has just been argued in this very section, it is appropriate to recall once again that this allegation was already made against the Initiation Agreement, relating to the concurrent offense, and a response was given justifying and arguing why the existence of concurrent offenses is not considered, and furthermore, the non-applicability of Article 29 of the LRJSP is justified. Therefore, it is appropriate to refer to the arguments put forward that are transcribed in section Third of the Legal Basis IV of this Resolution.

Thus, once it has been argued and justified not only that the existence of concurrent offenses is not considered, as well as the reasons why Article 29 of the LRJSP is deemed inapplicable, the change of criteria is legitimate and not contrary to law.

In this regard, the Judgment of March 12, 2018, of the High Court of Justice of Madrid, Administrative Litigation Chamber, Section 4 (Rec. 761/2017), states, on the occasion of the review of a sanctioning procedure, that:

"(...) the Administration may depart from what was previously resolved by justifying the change (art. 35.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations). As the Supreme Court points out in its Order of December 4, 1998, "... for the doctrine of the Administration's own acts to apply, it is fundamentally necessary that a first body of the Administration has issued a first declarative act of rights and then that the second revokes the decision made in the first," and this circumstance does not occur in this case because the present administrative act of tax liquidation does not revoke any decision made in a previous act relating to the same tax concept nor is there an express declarative act that is now being modified.

For these purposes, it is necessary to distinguish between the effectiveness of the Administration's own acts and the binding nature of the Administration to the interpretative precedents applied in previous situations since, in the case being questioned, and using the words of the Supreme Court (judgment of February 25, 2000), one cannot speak of "own act but at most a change of criteria and interpretation, which is perfectly valid." Likewise, the STS of June 27, 2000 refers:

"... the principle of acting against one's own acts could not be taken to extremes that would obstruct the legality of a particular action, merely due to the existence of another previous act of a different nature even if it was not supported by legality, just as equality can only exist within the scope of legality, as is sufficiently well known."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

under penalty of potentially consolidating illegal or non-compliant resolutions forever, irreversible and impossible to modify subsequently." In the same vein, the High Court has expressed itself in other Judgments. Thus, in the ruling of February 1, 1999, it states that "this principle cannot be invoked to create, maintain, or extend in the field of public law, situations contrary to the legal system, or when the preceding act contradicts the purpose or interest protected by a legal norm that, by its nature, is not susceptible to shelter a discretionary action of the Administration that implies the recognition of rights and/or obligations arising from its own acts. In other words, the doctrine of acts of one's own without the limitation just exposed could introduce into the realm of public law relations the principle of autonomy of will as an ordering method of matters regulated by imperative norms, in which the public interest safeguarded by the principle of legality prevails; a principle that would be violated if validity were given to an action of the Administration contrary to the legal system solely because it has been decided by the Administration or because it responds to a precedent of it. (...) or, in other terms, it cannot be said that the trust placed in an act or precedent that is contrary to the imperative norm is legitimate" (the emphasis is ours).

Furthermore, and to elaborate further, this criterion of understanding that Article 29 LRJSP is not applicable is not new as it has been applied in sanctioning files prior to the present one. By way of example, PS/00020/2023 and PS/00667/2023 are noted.

Finally, I-DE argues that the application of Article 29 is also a possibility recognized by Guidelines 4/2022, regarding the calculation of administrative fines under the GDPR, where the criteria that the administrative authority must follow to evaluate, prior to the imposition of the sanction, the possible concurrence of these are expressly stipulated.

In this regard, it is noted that, concerning the citation of Guidelines 04/2022 from the CEPD on the calculation of administrative fines in accordance with the GDPR, in its version 2.1, adopted on May 24, 2023, reference is made in section 22 to three types of concurrence, namely, of infringement, unit of action, and plurality of actions: "When examining the analysis of the traditions of the Member States regarding concurrency norms, as indicated in the jurisprudence of the CJEU, and taking into account the different areas of application and the legal consequences, these principles can be grouped approximately into the following three categories: - Concurrence of infringements (chapter 3.1.1), - Unit of action (chapter 3.1.2), - Plurality of actions (chapter 3.2).

In cases of concurrence of infringements, the provision established in this regard is contained in Article 83.3 of the GDPR, which establishes a quantitative limit in these cases of concurrence: "If a controller or a processor intentionally or negligently violates, for the same processing operations or linked operations, various provisions of this Regulation..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Regulation, the total amount of the administrative fine shall not exceed the amount provided for the most serious infringements."

Furthermore, at this point, we must recall that the severity of the infringements of the GDPR is determined in accordance with the rules established in this regulation and not in the LOPDGDD. The classification of infringements is regulated in Article 83, paragraphs 4, 5, and 6 of the GDPR, while the qualification of infringements as very serious, serious, or minor solely for the purposes of prescription is provided for in Articles 72, 73, and 74 of the LOPDGDD.

Lastly, and no less importantly, the AEPD does not sanction for the same offense, as I-DE claims, but it has been established through proven facts not rebutted by I-DE, the commission of two differentiated infringements, classified in a differentiated manner, and there is, moreover, no medial concurrence in the specific case.

For all the above, the present allegation is dismissed.

FIFTH: On the non-existence of a violation by I-DE of Article 32 of the GDPR

I-DE again indicates that it had carried out a risk analysis regarding the processing of data from access

to GEA that could generate risks to the rights and freedoms of the data subjects, as well as implemented security measures that allowed for the mitigation of the mentioned risks.

I-DE does not agree that this Agency understands that the security measures were insufficient due to the existence of a vulnerability in GEA that led to the breach of personal data, as it believes that the measures adopted by I-DE were robust despite the occurrence of a security incident, which it does not deny, but it does deny that this outcome necessarily determines the insufficiency of the measures adopted by I-DE.

I-DE also points out that, even if the AEPD intends to indicate that the vulnerability ultimately detected was "avoidable and identifiable," the truth is that it had not been, despite the adoption by I-DE of all the guidelines established by the Iberdrola Group to preserve the security of the information being processed, just as it was also not "avoidable and identifiable" that a compromise occurred in the credentials of a GEA user (...), as indicated by the conclusions of the forensic report provided by my representative (page 519 of the administrative file), without it being proven in any case that the exfiltration took place as a result of the manner in which password generation was established in the application, as the AEPD asserts emphatically.

In this regard, I-DE understands that it is obvious to indicate that the state of the art of pentesting techniques does not guarantee one hundred percent the detection of each and every vulnerability, which cannot be classified, as the AEPD seems to consider, as obvious, nor can they be considered "avoidable and identifiable."

Therefore, it argues that the reasoning maintained by the AEPD can only be classified as circular because, being evident that the jurisprudence has highlighted that the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/88

The obligation to adopt security measures is one of means and not of results. The AEPD conducts an assessment of the alleged non-compliance by I-DE with the obligation to implement security measures, reversing the reasoning that should be followed for this purpose, by indicating throughout its Proposal for Resolution that, ultimately, the measures were objectively inadequate due to the fact that an attack could indeed occur and the security breach took place.

I-DE argues that, in this way, the AEPD seeks to evade the doctrine upheld by the Supreme Court in its ruling of February 15, 2022, referring to the insufficiency of the measures, but ultimately its reasoning is that the result is taken into consideration as a premise to conclude that the means were inadequate before it occurred.

Therefore, I-DE reiterates everything indicated in the written allegations to the Initiation Agreement and brings back into discussion the ruling of the Supreme Court just mentioned, since the AEPD only intends to create an appearance that the result is not considered a determining fact of the alleged infringement of Article 32, when, as has been proven, said result is the premise on which the AEPD bases the alleged insufficiency of the measures adopted by my represented party.

In response to this, it is necessary to indicate, first of all, that the risk analysis of the processing carried out from access via the GEA application does not show any measures to be adopted to mitigate the alleged detected risks. In fact, it is an analysis based on a document attached by I-DE as Document No. 8, an explanatory document of the logic followed for calculating the risk level according to this methodology. This methodology is implemented in an automated manner in the corporate tool for recording processing activities, so that in the very registration process it determines the risk level of the processing. Thus, the application of this methodology in relation to the processing ***PROCESSING.1 resulted in a MEDIUM risk level, as recorded in Document No. 7 referred to above.

In the aforementioned Document 8, certain threats or circumstances are detailed such as "vulnerable groups," "access to personal data by more than 10 people," "international transfers," "large-scale processing," and "profiles with legal effects." These circumstances are established as questions, and depending on whether the answer is "yes" or "no," a result is applied:

(...)

Several of these questions appear in Document 7 referenced by I-DE, which seems to be the Record of Processing Activities of the activity affected by the personal data breach, in which the answers are "Yes" or "No," indicating a "Medium" risk, but nothing more. That is to say, no measures adopted or to be adopted to mitigate that medium risk are indicated. Nor is it specified whether it is an inherent risk or a residual risk.

Furthermore, as indicated in the Proposal for Resolution in response to this same allegation, also in view of the aforementioned Document 8, this analysis is not...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
63/88

focused on the risks of variable probability and severity that the processing may entail for the "rights and freedoms of individuals," such as physical, material, or immaterial damages, particularly issues of discrimination, identity theft, fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where individuals are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where personal aspects are evaluated, particularly the analysis or prediction of aspects related to job performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of individuals, etc., all in accordance with Recital 75 of the GDPR.

For its part, Article 28.2 of the LOPDGDD states that "In adopting the measures referred to in the previous paragraph, the data controllers and processors shall take into account, in particular, the greater risks that could arise in the following cases:

- a) When the processing could generate situations of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic, moral, or social harm to the affected parties.
- b) When the processing could deprive the affected parties of their rights and freedoms or could prevent them from exercising control over their personal data (...)."

Furthermore, as explained in the guide "Risk Management and Impact Assessment in Personal Data Processing" by the AEPD, "The GDPR establishes the obligation to manage the risk that processing poses to the rights and freedoms of individuals. This risk arises both from the very existence of the processing and from its technical and organizational dimensions. The risk arises from both automated data processing and manual processing, from the human elements and the resources involved. The risk arises from the purposes of the processing and its nature, as well as from its scope and the context in which it operates."

However, as already indicated, these risks have not been assessed. The damages to individuals, whether material or immaterial, have not been evaluated, or at least it is not evidenced that this has been done, thus lacking a risk analysis focused on the protection of the rights and freedoms of the affected parties. Furthermore, it is also not indicated what security measures should be adopted to mitigate the identified "Medium" risk.

Therefore, I-DE has not substantiated its claim that "it had carried out an analysis of the risks that the processing of data from access to...

64/88

GEA could generate risks to the rights and freedoms of the interested parties, as well as implement security measures that allowed for the mitigation of the aforementioned risks.

Secondly, regarding the fact that I-DE had implemented robust measures and that this Agency has linked the alleged non-compliance with Article 32 to the outcome of the incident, bringing back to the fore what was stated by the Supreme Court in its ruling of February 15, 2022 (cassation appeal

7359/2020), it is noted that, as already responded to this same allegation in the Proposal for Resolution, the deficiencies detected that constitute the non-compliance with Article 32 of the GDPR existed independently of the attack and the security breach that occurred.

Thus, in the present case, there was a vulnerability in the GEA web application prior to the attack, which was exploited by the cybercriminal. As has been established in the Proven Facts, the attack occurred from a validly logged-in user (...).

Therefore, the above demonstrates the existence of a web application with a vulnerability that allowed:
- (...)

Additionally, as a subsequent measure to prevent incidents like the one that occurred, I-DE proceeded to modify the GEA application (...).

On the other hand, as existing security measures prior to the incident, they pointed out, among others, the following:

(...). And it is precisely this vulnerability that was exploited by the attacker during the security breach.
(...).

From the above, it can be deduced that this attack could have been avoided if that code had not been visible. Even more so considering that this is one of the requirements set forth in the indicated document, (...).

Furthermore, this vulnerability is identifiable in security assessments. However, during the investigative proceedings, I-DE has not demonstrated that it detected the vulnerability of the GEA application within the framework of the security assessment program implemented in the Iberdrola Group. Moreover, as indicated, the last review or security assessment of critical applications dates back to 2019, almost two and a half years before the incident, which means they were not being conducted very regularly considering the rapid advances in technology, as well as the sophistication of cyberattacks, in addition to the fact that no results obtained have been provided or explained.

Therefore, the GEA application contained an avoidable and identifiable vulnerability that was exploited by the attacker. This clearly demonstrates a non-compliance with Article 32 of the GDPR, as it requires appropriate measures to ensure a level of security appropriate to the risk, taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing.
(...)

Thus, all of this demonstrates that the security measures at the time of the incident were not appropriate for adequate protection of personal data according to the risks of the processing and considering the state of the art and the costs at the time.

From the above, this Agency has in no way indicated that the exfiltration occurred as a consequence of how the password generation was established in the affected application. What has been indicated is that the attack took place by exploiting the vulnerability in that application consisting of the visibility, from a correctly validated session, (...).

In addition to this fact, what has been indicated by this Agency is that there were also other deficiencies in the security measures, such as a password policy (...).

These are deficiencies in themselves, independently, it is emphasized, of the specific incident that occurred and of the personal data breach that took place. However, the fact cannot be overlooked that the vulnerability in the GEA application was precisely the one exploited by the attacker who, moreover, initially managed to access validly logged in without the illegitimate exfiltration of information being detected at first, and it has not been possible to know with total certainty how the attacker obtained the credentials of a user, as indicated in the report issued by the company SIA regarding the incident:
(...)

Furthermore, the SIA company itself, in its recommendations, explicitly indicated:

- (...)

Regarding the possibility of access to the web application from suspicious or malicious IPs or, at least, not necessary for the business, it should also not be forgotten that, as pointed out in the report by the SIA company, (...).

Therefore, this Agency has in no way based its findings on the result of the cyberattack to justify the non-compliance with Article 32 of the GDPR, as, as has been pointed out, such non-compliance already existed prior to and independently of the attack suffered, which highlights that appropriate

measures were not in place to ensure an adequate level of security.

Finally, regarding the Judgment of the Supreme Court of February 15, 2022 (cassation appeal 7359/2020), indicated by I-DE, it is noted, as already stated in the Proposal for Resolution, that the aforementioned Judgment indeed indicates, regarding security measures in data protection, that "... the obligation that falls on the data controller and the data processor...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

66/88

Regarding the adoption of necessary measures to guarantee the security of personal data, it is not an obligation of result but of means, and the infallibility of the measures adopted is not required. It is only required to adopt and implement technical and organizational measures that, in accordance with the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of alteration, loss, unauthorized processing, or access." (the emphasis is ours)

However, the Judgment continues by indicating, in the specific case being analyzed, that "...the program used for collecting customer data did not contain any security measures that would allow verifying whether the email address entered was real or fictitious and whether it actually belonged to the person whose data was being processed and who provided consent for it. The state of technology at the time these events occurred allowed for the establishment of measures aimed at verifying the authenticity of the email address, conditioning the continuation of the process on the user receiving the contract at the provided address and only from there providing the necessary consent for its collection and processing. Measures that were not adopted in this case.

(...) Thus, at the time these events occurred, there were technical measures related to the registration process that would have prevented the leakage of personal data that occurred. This implies that the technical measures adopted failed to meet the security conditions required under Article 9.1 of Law 15/1999, thus incurring the infringement provided for in Article 44.3.h) consisting of "Maintaining files, premises, programs, or equipment containing personal data without the due security conditions that are determined by regulation [...]".

It should be noted, first of all, that this judgment is issued under the regulations prior to the GDPR, in which, according to the system provided in the LOPD and the RLOPD, security measures were perfectly standardized. There has been a shift from a system with standard and static security measures for any data controller to specific security measures for each organization (adapted to its characteristics and idiosyncrasies), which consider the specific risks of the entity in question; moreover, they are now dynamic, in such a way that they are not exhausted with the implementation of appropriate security measures at the beginning of the processing, but must adapt to the risks that may arise.

The new regulation provided in the GDPR significantly expands the obligations of the data controller and its scope of action and responsibility, now clearly extending to actions carried out by its data processors, which fall within its area of responsibility.

Secondly, the Supreme Court Judgment cited considers, in relation to an infringement of Article 9 of the LOPD, that "the obligation that falls on the data controller and on the data processor regarding the adoption of necessary measures to guarantee the security of personal data is not an obligation of result but of means, and the infallibility of the measures adopted is not required. It is only required to adopt and implement...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

67/88

technical and organizational measures, which, according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the

prevention of alteration, loss, unauthorized processing, or access."

In this regard, it specifies that "It is not enough to design the necessary technical and organizational means; their correct implementation and appropriate use are also necessary, such that one will also be liable for the lack of diligence in their use, understood as reasonable diligence considering the circumstances of the case."

As has been demonstrated and argued throughout this sanctioning procedure, it is considered that appropriate security measures were not implemented to ensure adequate security relative to the risk, even if there had not been a breach of personal data.

In this regard, this Agency wishes to point out that it does not consider the obligation to implement security measures imposed by data protection regulations to be a result-oriented obligation rather than a means-oriented one. However, it is equally true that I-DE did not have, prior to the incident, measures that "according to the state of technology and in relation to the nature of the processing carried out and the personal data in question, reasonably allow for the prevention of alteration, loss, unauthorized processing, or access."

Therefore, while it is inferred from the Judgment that the obligations established by Article 32 of the GDPR are means-oriented, it also makes clear that if, at the time the incident occurred, there were adequate technical measures in place to prevent or mitigate its effects and they were not applied, this constitutes a breach of the aforementioned obligation imposed by the GDPR and, consequently, a violation thereof.

In the present case, as has been repeatedly pointed out, there was a vulnerability in the GEA application, (...). This clearly demonstrates a breach of Article 32 of the GDPR, as it requires appropriate measures to ensure a level of security adequate to the risk, taking into account the state of the technology, the costs of implementation, and the nature, scope, context, and purposes of the processing.

For the reasons stated, the allegation is dismissed.

SIXTH: On the non-existence of a violation of the principle of confidentiality and integrity.

I-DE again notes the absolute identity between the two violations attributed to it to the extent that the alleged violation of Article 5.1(f) of the GDPR either results from the alleged violation of Article 32 of that Regulation or arises directly, immediately, and exclusively from this second alleged breach, that is, from the lack of adequate security measures.

I-DE points out in this regard that the AEPD has not considered the existence of any violation that does not refer to security measures, as no such violation has been...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

68/88

indicating no measures that have ceased to be complied with other than those related to security that may be required.

In this regard, it was already indicated in the Resolution Proposal that when Article 5.1(f) of the GDPR refers to appropriate technical or organizational measures to ensure the rights and freedoms of data subjects within the framework of GDPR compliance management, it does so in the sense intended in Article 25 of the GDPR concerning privacy by design.

This provision states that,

"Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of data subjects" (the underlining is ours).

It should be noted that there are multiple technical or organizational measures that are not

security-related and that the data controller can implement as a means to guarantee this principle. In this sense, I-DE has not demonstrated that it has complied with the provisions of this article, as it has not been evidenced that, in accordance with the risks of varying likelihood and severity that the processing poses to the rights and freedoms of natural persons, it has applied appropriate technical and organizational measures such as, for example, pseudonymization, designed and aimed at effectively applying the principles of data protection, among which is the principle of confidentiality. Therefore, the GDPR requires the applicability of data protection by design and the necessity to manage both the risks to the rights and freedoms of individuals and the impact that a data breach could have on those rights and freedoms, especially in web environments, as they can affect a large volume of the population.

As stated in the guidelines for processing that involves data communication between public administrations of this Agency, whose reasoning is extrapolable to large organizations that handle a significant amount of data, there are always risks associated with personal data breaches. However, these will be particularly considerable in the processing of personal data carried out by large public and private organizations that are serving a large portion of citizens, and even more so if they are interconnected. It is very important to consider that the risk posed by data breaches

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

69/88

The personal nature of such treatments does not depend so much on whether sensitive and/or specially protected categories of data are involved, but rather on the consequences for fundamental rights that may arise from a breach of information.

To estimate the impact that a personal data breach could have, one must consider the consequences that would arise from its realization. One way to do this is, before a breach occurs, to contemplate the possible scenarios of a personal data breach, determine its consequences, and evaluate how it affects the rights and freedoms of the individuals concerned, especially if it involves irreversible consequences for their fundamental rights.

Regarding the appropriate measures relative to the level of risks to rights and freedoms, Article 24.1 of the GDPR establishes that the measures to be adopted in a processing operation to ensure and demonstrate compliance with the Regulation must take into account the scope, context, and purposes of the processing, particularly considering the extent of the subjects affected by it and the risk it poses to fundamental rights, and not just the type of data involved.

In the aforementioned Guidelines, it is stated that “the technical and organizational measures adopted must be specifically aimed at minimizing the identified risks to the rights and freedoms of potential personal data breaches. This implies that the data controller must assess the risks that may arise, design measures aimed at minimizing their probability and impact, and determine to what extent such measures are appropriately managing the specific risks in a dynamic process.”

It is added that “appropriate measures must be selected and implemented from the design of the processing operations so that all risk contexts for rights and freedoms are considered. It should be noted that some measures will be more effective in preventing or mitigating the direct impact on individuals, while other measures will primarily address the social impact on fundamental rights. A high level of data protection by default must be applied...”

It is undisputed that a personal data breach may occur; therefore, within the risk management of a particular organization, precisely because a breach may occur, this scenario must be evaluated as an integral part of risk management for the purposes of (i) adopting all types of appropriate technical and organizational measures to prevent its occurrence and (ii) determining post-factum measures to minimize damages. In this regard, the aforementioned Guidelines explain that “in light of the possible scenarios of realization of different types of breaches, at least the following questions must be addressed from the design of the processing and prior to its implementation:

- What personal and social impact could a personal data breach have if it materializes.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
70/88

- What data protection measures should be implemented a priori to minimize the personal and social impact that a materialized breach could produce.
- What response measures should be planned and executed a posteriori, once the breach has occurred, to minimize the personal and social impact.

Therefore, its management cannot be based exclusively on the field of cybersecurity, but must encompass all areas in which the processing takes place, since otherwise, risk management would not be complete and, therefore, would be useless. For this reason, it is essential to adopt specific measures for data protection from the design stage and by default, as well as measures for effective management of the consequences of the breach aimed at protecting the fundamental rights of individuals.

As noted, there are multiple technical or organizational measures that are not security-related and that the data controller can implement as a means to guarantee the principle of confidentiality.

In this regard, I-DE has not demonstrated that it has complied with the provisions of the GDPR, as it has not been proven that, in accordance with all of the above, it has evaluated those risks and applied appropriate technical and organizational measures aimed at effectively implementing the principles of data protection, including measures aimed at ensuring the principle of confidentiality. Furthermore, it should be emphasized that in this case, the breach of the principle of confidentiality has materialized.

Moreover, and aside from the above, even in the risk analysis to adopt the security measures of Article 32, it has not been indicated what measures should be adopted to mitigate that "medium" risk indicated as affecting the processing activity impacted by the breach, as will be indicated later in more detail in the response to the Fourth Allegation of this Legal Basis.

Therefore, in the case examined, as stated in the proven facts, there is a clear loss of confidentiality since unauthorized third-party access to the personal data processed by I-DE has occurred, which does not imply objective liability, as I-DE was not diligent in not ensuring, in this way, adequate security through the application of appropriate technical and organizational measures, not only of security but of all kinds.

Regarding what I-DE has indicated concerning the fact that this AEPD has not demonstrated in any way the materialization of the risk posed by the loss of confidentiality for the affected individuals, and that no I-DE customer has seen their rights affected as a result of the security breach that occurred, which it understands does not allow for considering a principle to be infringed and imposing as a consequence of such alleged infringement a fine of two million euros based on mere potentiality or the consideration that a high risk of fraud could occur, which has not been demonstrated in any way.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
71/88

In this regard, and as already indicated in the Resolution Proposal, what is attributed to I-DE is the violation of the principle of confidentiality, as it is established that, following a cyberattack against the GEA website, there was unauthorized access to personal data and the extraction of such data by an unauthorized third party, which resulted in the loss of confidentiality and control over numerous personal data (name and surname, ID number, postal address, fax, email, phone number, customer code) affecting 1,350,000 customers of I-DE. Therefore, the risk did materialize; there was a loss of confidentiality and a loss of control over the data. What is guaranteed is confidentiality in order to avoid the serious damages that its breach can cause, as it poses a high risk to the affected parties in the event of a breach of confidentiality, leading to fraudulent use of the data: identity theft for online

contracting, phishing, financial fraud, etc. The loss of confidentiality has already occurred in this case due to the access and exfiltration, so it is no longer a matter of "probability" of risk, but rather the realization of this risk causing damage in itself. This constitutes a breach of the duty to guarantee the confidentiality of personal data, as indicated, since Article 5.1.f) states that data must be processed in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing.

Furthermore, regarding the assertion that none of its customers have been affected in any of their rights as a result of the security breach, I-DE overlooks that the very loss of confidentiality suffered implies that the core of the fundamental right to data protection is affected, which is none other than the control over personal data.

As for the indication of the high risk that such data, in the hands of cybercriminal(s), could be used fraudulently, this was stated to express what the loss of confidentiality entails, but it is not necessary in any way, to understand that Article 5.1.f) has been violated, for such risks of fraudulent use to materialize, because what has materialized with the breach is the loss of confidentiality of the personal data processed by I-DE, which is what is exclusively attributed to it.

For the reasons stated, the allegation is dismissed.

SEVENTH: On the violation of the principle of proportionality to the detriment of I-DE's rights I-DE draws attention to the fact that the same aggravating circumstances have been applied in relation to the two infringements attributed, which it understands evidences the extent of the connection between both in total, proceeding with the application of what was invoked in allegations Second and Third (violation of the principle of non bis in idem and existence of medial concurrence).

In this regard, it has already been indicated to it, concerning the application of identical aggravating factors in both infringements, that the circumstances provided for in Article 83.2 of the GDPR and those set forth in Article 76.2 of the LOPDGDD are the only ones that can be applied by the AEPD for any infringement.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
72/88

What is decisive in this case is not that they coincide in their use, but the reasoning established for their consideration.

Furthermore, I-DE alleges the improper application of Article 83.2.a) of the GDPR, drawing attention to the fact that it has been considered appropriate to aggravate the imposed sanction due to the occurrence of a loss of confidentiality of personal data, both in relation to Article 32 and Article 5.1.f). Thus, I-DE argues that, concerning the infringement of Article 32, according to the traditional concept of security in systems, it aims to guarantee the integrity, confidentiality, and availability of information. Therefore, if the AEPD considers that the occurrence of a breach of confidentiality would aggravate the conduct consisting of the alleged absence of such security measures, any accusation for the alleged infringement of Article 32 would be aggravated by the AEPD, which would lead to the inclusion in the catalog of infringements of a kind of aggravated type by its very nature, which, however, is not included in the GDPR or in the LOPDGDD.

In this regard, it should be noted, contrary to what has been argued, that the violation of confidentiality is not necessary or essential for the commission of the infringement of Article 32, since, as previously indicated, Article 32 can be violated due to the absence of appropriate security measures or due to inefficiency in their use or implementation, without necessarily having occurred a breach of personal data. It is a different matter that the infringement of Article 32 is evidenced as a result of the materialization of a violation of the security of personal data, which, by its very definition, involves "any breach of security that results in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data" (paragraph 12 of Article 4 of the GDPR).

Therefore, in the present case, there was a vulnerability in an application of I-DE, in addition to other deficiencies such as in the password policy and in the existing limits on access to the application from

suspicious IPs that are not necessary for the development of the business, which demonstrated that I-DE was not applying appropriate measures to ensure a level of security adequate to the risk of its processing (not to forget that it is a web application, that is, accessible from the internet), which in itself constitutes a violation of Article 32. If, moreover, these deficiencies have allowed or facilitated, as is the case, that a breach of personal data has occurred (in this case, a breach of confidentiality), there is no obstacle to considering such a violation as an aggravating circumstance under Article 83.2.a), which allows taking into account the "nature, gravity, and duration of the infringement, considering the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damages they have suffered" (the underlining is ours). Regarding the application of the aggravating factor of Article 83.2.a) for the violation of Article 5.1.f), while it is true that the violation of confidentiality is not appropriate as a circumstance to be taken into account to aggravate the infringement, since it...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
73/88

is subsumed within the very type of infringement, it is also true that the aforementioned provision, Article 83.2.a) of the GDPR, has been applied as an aggravating factor taking into account, moreover, the number of affected parties, which is very numerous, amounting to more than one million people (1,350,000), as well as the fact that numerous personal data were stolen (name and surname, ID number, postal address, email, phone number, customer code), therefore it is appropriate to continue considering these circumstances as aggravating factors, so Article 83.2.a) of the GDPR remains applicable.

Regarding I-DE's understanding that in relation to this aggravating factor, it is intended to take into account alleged damages suffered, which have not been substantiated by the AEPD, it is noted that what is taken into account in this aggravating factor is the damage and risk that the loss of confidentiality itself entails, which involves a total loss of control over one's own personal data and the high risk that it may be used fraudulently, as it has been stolen by a cybercriminal.

On the other hand, I-DE argues that the aggravating factor of Article 83.2.b) of the GDPR relating to the existence of negligence cannot be applied to it since, in the Judgment of the European Court of Justice, dated December 5, 2023 (case C-807/21), it is stated that:

"75 Consequently, it must be declared that Article 83 of the GDPR does not allow for the imposition of an administrative fine for an infringement covered by paragraphs 4 to 6 without demonstrating that such infringement was committed intentionally or negligently by the data controller and that, therefore, culpability in the commission of the infringement constitutes a requirement for the imposition of the fine."

From this, I-DE deduces that if intentionality or negligence is necessary for the infringement to be considered committed, it is difficult to consider that the most serious form of culpability required can act as an aggravating circumstance, and even less so based on a subjective criterion, such as the volume of I-DE.

In contrast, it should be noted that it is one thing that, in order to attribute an administrative infringement, the existence of intention or negligence is necessary, and another that the existence of a negligence especially highlighted by the circumstances of the case cannot be used as an aggravating factor. The opposite would be contrary to Article 83.2.b) itself, which establishes that "In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

b) the intentionality or negligence in the infringement."

Thus, in any infringement of the data protection regulations, the existence of intentionality or negligence must be present. This applies to both natural persons and legal entities as data controllers, whether it is a small company with little involvement in the processing of personal data or a large company, a multinational, etc., and with continuous and large-scale processing of personal data, for example.

Therefore, once it is determined that, as a premise, this subjective culpability element is present, this does not prevent the consideration of the aggravating factor of intentionality or negligence indicated, as it is considered that, in accordance with the...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
74/88

specific circumstances of the case, a different degree of intent or negligence in the actions of the infringing party may be considered. Thus, in accordance with the Guidelines 04/2022 of the European Data Protection Board on the calculation of administrative fines under the GDPR, in its version 2.1, adopted on May 24, 2023, it states the following:

“4.2.2 — Intentional or negligent nature of the infringement

55. In its previous guidelines, the EDPB stated that “in general, intent includes both knowledge and will regarding the characteristics of an offense, while ‘unintentional’ means that there was no intention to cause the infringement, even though the data controller/processor failed to comply with the duty of care required by law.

Example 4 — Illustrations of intent and negligence (from WP 253)

“The circumstances indicative of intentional infringements may be an unlawful processing explicitly authorized by the high management hierarchy of the data controller, or despite the advice of the data protection officer or in violation of existing policies, for example, the obtaining and processing of data about employees of a competitor with the intention of discrediting that competitor in the market. Other examples here may include:

- the modification of personal data to give a misleading (positive) impression of whether objectives have been met; we have seen this in the context of objectives for hospital waiting times
- the trading of personal data for commercial purposes, that is, the sale of data as ‘opted-in’ without checking or ignoring the opinions of the data subjects on how their data should be used

Other circumstances, such as the failure to read and comply with existing policies, human error, the lack of verification of personal data in the published information, the failure to implement technical updates in a timely manner, the failure to adopt policies (rather than simply the lack of enforcement) may be indicative of negligence”;

56. The intentional or negligent nature of the infringement [Article 83, paragraph 2, letter b), of the GDPR] must be assessed taking into account the objective elements of conduct derived from the facts of the case. The EDPB emphasized that it is generally accepted that intentional infringements, “demonstrating disregard for the provisions of the law, are more serious than unintentional ones.” In the case of intentional infringement, it is likely that the supervisory authority will attribute more weight to this factor. Depending on the circumstances of the case, the supervisory authority may also attribute weight to the degree of negligence. At best, negligence could be considered neutral.” (the underlining is ours)

In the present case, the aggravating factor of negligence was noted as the detected vulnerability could have been avoided, being furthermore an identifiable vulnerability in the security assessments.

Likewise, in relation to the infringement

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
75/88

of Article 5.1.f) of the GDPR, the negligence shown by I-DE was also considered an aggravating factor, as it has been pointed out that, due to its subjective circumstances and the large number of clients it has, a higher degree of professionalism and diligence is required in the duty to guarantee the confidentiality of the personal data of its numerous clients.

Regarding the consideration of I-DE's size as an aggravating factor, it should be noted that the same level of diligence cannot be required of a company like I-DE as that required of a natural person or a

small business, for example. This implies that a higher level of diligence is demanded because the level of professionalism is greater.

It is worth recalling, in this regard, the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

Finally, contrary to what I-DE has stated, the consideration of this aggravating factor of negligence has in no way meant that the maximum limit of the sanction to be imposed has been increased, as the maximum limits are established in paragraphs 4 and 5 of Article 83 of the GDPR, which allow for the imposition of a sanction of 10,000,000 euros or 2% of the total annual global turnover and 20,000,000 euros or 4% of the total annual global turnover, respectively. Therefore, at no time has the maximum amount of the sanction that could be imposed as a result of the application of the aggravating factors been established, as indicated by I-DE.

Regarding the aggravating circumstance set forth in Article 76.2.b of the LOPDGDD, I-DE states that its conduct is being aggravated merely by the fact of belonging to a specific sector of activity. In this respect, it is emphasized that this provision does not take into account the specific activity to which I-DE is dedicated (energy distributor), but rather its connection with the processing of personal data, as it carries out massive and large-scale processing (of 21 million clients), through computer applications and web applications and continuously.

In this sense, the Spanish legislator has considered including in Article 76 of the LOPDGDD that: "2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

(...)

b) The connection of the offender's activity with the processing of personal data."

This Agency simply takes that circumstance, provided by the legislator, into consideration when deciding on the imposition of the administrative fine.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

76/88

Finally, I-DE alleges a breach of the principle of equal treatment when considering the precedents of this Agency. Thus, it points to the procedure PS/000179/2020, in which it indicates that a lesser sanction was imposed despite understanding that the circumstances were more serious, but, above all, in that file, no sanction was imposed for the violation of Article 5.1.f) of the GDPR, despite the manifest existence of a breach of data confidentiality. Therefore, the AEPD has modified its criteria, as converting what was previously considered a violation of Article 32 of the GDPR into two violations, now referencing Article 5.1.f) of the GDPR, and significantly multiplying the total amount of the violation, constitutes a flagrant breach of the principles of equality, legal certainty, and public faith. It also states that this goes against the doctrine of acts of one's own.

In response, as already indicated in the Proposal for Resolution, the circumstances and facts of procedure PS/000179/2020 are neither the same nor comparable, and there can be no equality in illegality; therefore, it is not appropriate to attempt to equate sanctions for different facts and circumstances. Consequently, it is appropriate to refer to the response provided regarding this same allegation, which is fully transcribed in Section Six of the Legal Basis IV of this Resolution.

Regarding what I-DE claims concerning the violation of the principle of equality in that in PS/000179/2020 only a sanction was imposed for a violation of Article 32 and no violation of Article 5.1.f) of the GDPR was considered, despite there also being a breach of confidentiality, and that this also goes against the doctrine of acts of one's own, it is noted that I-DE has only selected and brought

up this file to defend an alleged unequal treatment, but, however, overlooks the numerous sanctioning procedures existing prior to the present one in which, after a breach of confidentiality occurred, sanctions have been imposed for violating both provisions. By way of example and without being exhaustive, as there are more, the following should be indicated: PS/00444/2021, PS/00420/2021, PS/00528/2021, PS/00099/2022, PS/00113/2022, PS/00164/2022, PS/00419/2022, PS/00168/2022. Finally, regarding procedure PS/0002/2023, in which two sanctions were also imposed for violating both Article 32 and Article 5.1.f) of the GDPR and which also refers to a company in the electricity sector, I-DE brings it up for comparison, because there, the total sum of the two sanctions for these two violations was an amount that only exceeds by 500,000 euros the amounts imposed on I-DE, despite there being affected parties. It is again noted that the facts and circumstances are different and that, for this reason, a different (in this case, higher) fine was imposed, in addition to other fines for other different violations that were considered.

In this regard, it is again recalled that, in matters of data protection, the technical and organizational security measures to be adopted by the data controllers and other obligations required by the GDPR must be appropriate in relation to the specific risks posed by the specific treatments carried out by each controller. Therefore, when analyzing the diligence of some...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

77/88

and others in compliance with the regulations must take into account the circumstances of each case, considering the nature, scope, context, and purposes of each processing, as there are no identical cases. In this regard, it should be noted that Article 83, in its paragraph 2, establishes that “Administrative fines shall be imposed, depending on the circumstances of each individual case...” (the underlining is ours)

Therefore, it is necessary to consider the circumstances of each individual case, as there are no two identical files and, consequently, no identical outcomes.

As a general and final consideration, it should be noted that none of the sanctions applied violate the principle of proportionality. Thus, it should be recalled that Articles 83.4 and 83.5 of the GDPR, where the infringement of Article 32 and that of Article 5.1.f) are respectively classified, establish limits on the amounts of fines that can be imposed that are far removed from those that have ultimately been established.

Thus, Article 83.4 of the aforementioned Regulation establishes that they will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount. In this regard, according to the entity Axesor, the turnover for 2022 of I-DE was ***CANTIDAD.2 euros, which would have allowed for a sanction of up to ***CANTIDAD.3 euros for the infringement of Article 32.

For its part, Article 83.5 of the GDPR establishes that they will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount. In this regard, according to the indicated turnover, it would have allowed for a sanction of up to ***CANTIDAD.4 euros for the infringement of Article 5.1.f).

Therefore, taking into account the above, as well as the negligence of I-DE in having a web application with the detected vulnerability, with a weak password policy and access permissions from suspicious and unnecessary IPs for the development of its business activity (and much less for the purpose of the application in question), from which personal data of its customers is accessed, and considering the high number of affected individuals whose personal data was exfiltrated by a cybercriminal, which represents an irreparable loss of control over personal data, with the risks that this entails, it cannot be said that the sanctions ultimately imposed violate the principle of proportionality, considering that “Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are in each individual case

effective, proportionate, and dissuasive” (the underlining is ours)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/88

VI

Integrity and Confidentiality

Article 5.1.f) "Principles relating to processing" of the GDPR states:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality').”

The principle of integrity and confidentiality of data requires a guarantee of security in the application of technical or organizational measures that prevent the alteration of personal data, its loss, unauthorized or unlawful processing or access. The existence of this fundamental right is not possible if confidentiality, integrity, and availability are not guaranteed.

Thus, the integrity and confidentiality of personal data are considered essential to prevent data subjects from suffering negative effects. Therefore, they must be processed in a manner that ensures adequate integrity and confidentiality of personal data, especially to prevent unauthorized access, processing, or use of such data.

Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees in the processing, with the aim of, under the principle of proactive responsibility, complying with and being able to demonstrate compliance, while respecting the fundamental right to data protection.

In this regard, it should be noted that the confidentiality of personal data is regulated in Article 5 of the GDPR and is, therefore, one of the principles relating to processing. The principles relating to processing are, on one hand, the starting point and the closing clause of the legal framework for data protection, constituting true guiding rules of the system with significant expansive force; on the other hand, having a high level of specificity, they are mandatory norms that can be infringed.

Article 5.1.f) of the GDPR establishes a clear obligation of compliance consisting of preventing unauthorized or unlawful processing by implementing appropriate measures of all kinds to ensure the confidentiality, integrity, and availability of the data.

Consequently, data controllers must be in a position to guarantee the confidentiality of personal data to prevent a third party from accessing data that does not belong to them, as it is precisely their responsibility to process personal data in accordance with the GDPR and LOPDGDD. For this reason, the diligence exercised by them is fundamental to avoid such unauthorized access.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

79/88

In the present case, the principle of confidentiality has been violated as it is established that after suffering a cyber attack against the management website for connections of I-DE (GEA), exploiting a vulnerability in it, there was an unauthorized access to personal data and the extraction of the same, which resulted in the loss of confidentiality and control over numerous personal data (name and surname, ID number, postal address, fax, email, phone number, customer code) affecting, among others, 1,350,000 customers of I-DE. This constitutes a breach of the duty to guarantee the confidentiality of personal data, as indicated, Article 5.1(f) states that they must be processed in such a way as to ensure an adequate level of security for personal data, including protection against unauthorized or unlawful processing.

Therefore, the risk of loss of confidentiality has materialized, having been usurped by a cybercriminal, which means that they can be used for unknown purposes (sold, communicated, published, etc.), all

without the consent of their owners, resulting in a total and absolute loss of control over them. Furthermore, it also entails a very high risk of fraudulent use of the same (identity theft, fraud, financial losses, etc.) or that they may serve any other purpose that under certain circumstances constitutes a threat to their owners. It should also be noted that most of the leaked personal data are data that cannot be modified or changed for others (name, surname, ID number, address...)

This loss of control over one's personal data translates into a violation of the fundamental right to data protection recognized in Article 18 of the Spanish Constitution, as indicated by the Constitutional Court (Judgment 292/2000, of November 30, 2000) "the fundamental right to data protection aims to guarantee individuals a power of control over their personal data, over its use and destination, in order to prevent its illicit and harmful trafficking for the dignity and rights of the affected party (...). The right to data protection guarantees individuals a power of disposition over that data."

For all the above reasons and in accordance with the evidence available at this time of the proposed resolution, it is considered that the known facts could constitute an infringement, attributable to I-DE, for violation of Article 5.1(f) of the GDPR.

VII

Classification of the infringement of Article 5.1(f) of the GDPR

The aforementioned infringement of Article 5.1(f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year limitation period:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VIII

Sanction for the infringement of Article 5.1(f) of the GDPR

In accordance with the evidence available, it is appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- Article 83.2(a) GDPR: Nature, gravity, and duration of the infringement.
- Number of affected parties: the number of affected individuals is very large, as it amounts to over one million customers of I-DE (1,350,000).
- Level of damages suffered: High. Numerous personal data (name and surname, ID number, postal address, email, phone number, customer code) were stolen from a very considerable number of customers of I-DE (1,350,000), thus losing all control over them, thereby emptying the fundamental right to personal data protection of its content, which, as indicated by the Constitutional Court in the aforementioned judgment, aims to guarantee individuals a power of control and disposition over their personal data, over its use and destination, in order to prevent its illicit and harmful trafficking for the dignity and rights of the affected party.
- Article 83.2(b) GDPR. Intentionality or negligence in the infringement: negligence is evident in the compliance and observance of the technical and organizational measures necessary to ensure the required security for the protection of personal data, specifically to guarantee the confidentiality of the same.

In this regard, it should be noted that I-DE is a large company that conducts large-scale processing, affecting numerous individuals (21 million people), which requires a higher level of diligence. It is worth recalling, in this sense, the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

As mitigating factors:

- Article 83.2.c) GDPR. Measures taken by the controller to mitigate the damages suffered by the data subjects: Positive. As soon as it became aware of the attack, it reacted as quickly as possible and took measures aimed at repelling it and preventing its recurrence (suspension of the web application; blocking of suspicious IPs, disconnections, etc.) and immediate activation of its corresponding internal protocols, which may have prevented a much more serious impact.

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- Article 76.2.b) LOPDGDD. Linkage of the offender's activity with the processing of personal data: The development of the business activity carried out by I-DE involves continuous and large-scale processing of personal data, as it states that it processes data of 21 million people. Therefore, it is a large company accustomed to the processing of personal data.

In accordance with the available evidence, taking into account the circumstances of the case and the criteria established in Article 83.2 of the GDPR regarding the infringement committed by violating what is established in Article 5.1.f) of the GDPR, a sanction of €2,500,000 (two million five hundred thousand euros) is established.

IX

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

appropriate organizational measures to ensure a level of security adequate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regular verification, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful

destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.

Article 32 does not establish static security measures; it is for the controller to determine which security measures are necessary to ensure the confidentiality, integrity, and availability of personal data. Therefore, the same data processing may involve different security measures depending on the specific circumstances in which that data processing takes place.

In line with these provisions, Recital 75 of the GDPR states: The risks to the rights and freedoms of natural persons, of varying severity and likelihood, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to discrimination issues, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal racial or ethnic origin, political opinions, religion.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

83/88

or philosophical beliefs, union membership, and the processing of genetic data, health-related data, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, particularly the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects. (the underlining is ours)

Furthermore, Recital 83 of the GDPR states: In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may particularly cause physical, material, or immaterial harm. (the underlining is ours)

In short, the first step in determining security measures will be the risk assessment. Once assessed, it will be necessary to determine the security measures aimed at reducing or eliminating the risks to data processing.

Data security requires the implementation of appropriate technical or organizational measures in the processing of personal data to protect such data against access, use, modification, dissemination, loss, destruction, or accidental, unauthorized, or unlawful damage. In this regard, security measures are key to ensuring the fundamental right to data protection. The existence of the fundamental right to personal data protection is not possible if confidentiality, integrity, and availability of such data cannot be guaranteed.

It should not be forgotten that, in accordance with Article 32.1 of the aforementioned GDPR, the technical and organizational measures to be applied to ensure an adequate level of security relative to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of natural persons.

Therefore, I-DE, when assessing risks and determining the appropriate technical and organizational measures to ensure an adequate level of security relative to the risk, is obliged to take into account the specific activity that constitutes its business, which involves the continuous and large-scale processing of personal data (numerous data to be collected, processed, stored...); the type of data processed: identifying, of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
84/88

contact, those related to the supply and consumption of electricity, current accounts, etc.); the context: use of a web application on the internet, that is, in a non-isolated environment, which entails risks arising from the interconnectivity that the network itself implies, which must be addressed in a specialized manner.

Therefore, due to the activity it engages in, I-DE is obliged to conduct a highly specialized risk analysis and implement appropriate technical and organizational measures to ensure an adequate level of security relative to the risk of its activities for the rights and freedoms of individuals.

In the present case, as previously noted, I-DE suffered a cyberattack on its GEA web application, causing a security breach consisting of a breach of confidentiality due to unauthorized access to personal data of its clients, contained in the Group's database, and an illicit exfiltration of the same. The GEA application is a web application of I-DE used for the management of electrical connections. It is published on the Internet for access by users (clients, installers, etc.) involved in the management process of those connection files.

(...)

All of the above demonstrates that I-DE was not sufficiently diligent in implementing appropriate security measures to prevent security incidents such as the one that occurred in this case, that is, it did not apply appropriate technical and organizational measures to ensure an adequate level of security relative to the risk of its personal data processing. Likewise, there is also a lack of necessary diligence in the process of regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of the processing. (Article 32.1)

Therefore, in accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to I-DE for violation of Article 32 of the GDPR.

X

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

85/88

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year statute of limitations: infringements that imply a substantial violation of the articles mentioned therein, and in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security relative to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

XI

Sanction for the infringement of Article 32 of the GDPR

In accordance with the available evidence, it is appropriate to grade the sanction to be imposed, according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- Article 83.2.a) GDPR: Nature, severity, and duration of the infringement.
- It is considered that the nature of the infringement is serious since it has resulted in a loss of confidentiality and, therefore, of irretrievable disposition and control over personal data.
- Number of affected parties: the number of affected individuals is very large, amounting to 1,350,000.
- Level of damages and losses suffered: High. Numerous personal data (name and surname, ID number, postal address, email, phone number, customer code) were stolen from a very considerable number of I-DE clients (1,350,000), thus losing all control over them, thereby emptying the fundamental right to the protection of personal data of its content, which, as indicated by the Constitutional Court in the previously mentioned ruling, seeks to guarantee individuals a power of control and disposition over their personal data, their use and destination, with the aim of preventing their illicit and harmful trafficking to the dignity and rights of the affected party.
- Article 83.2.b) GDPR. Intent or negligence in the infringement: negligence is evident in the compliance and observance of the technical and organizational measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

86/88

organizational measures to ensure adequate security for the protection of personal data, specifically to guarantee the confidentiality of such data. The detected vulnerability could have been avoided, and it is also a vulnerability identifiable in security assessments.

In this regard, it should be noted that I-DE is a large company that processes data on a large scale, affecting numerous individuals (21 million people), which requires a higher level of diligence and appropriate security measures to ensure the confidentiality of the personal data it processes.

It is worth recalling, in this sense, the Judgment of the National Court of 17/10/2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, indicates that "...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard."

As mitigating factors:

- Article 83.2.c) GDPR. Measures taken by the controller to mitigate the damages suffered by the data subjects: Positive. As soon as it became aware of the attack, I-DE's staff reacted as quickly as possible and proceeded to take measures aimed at repelling it and preventing its recurrence

(suspension of the web application; blocking suspicious IPs, disconnections, etc.) and immediate activation of its corresponding internal protocols, which may have prevented a much more serious impact.

Furthermore, it is considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

As aggravating factors:

- Article 76.2.b) LOPDGDD. Linkage of the offender's activity with the processing of personal data: The development of the business activity carried out by I-DE involves continuous and large-scale processing of personal data. Therefore, it is a large company accustomed to processing personal data. The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the establishment of a sanction of €1,000,000 (one million euros).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

87/88

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U., with NIF A95075578, for a violation of Article 5.1.f) of the GDPR classified under Article 83.5 of the GDPR, a fine of 2,500,000 euros (TWO MILLION FIVE HUNDRED THOUSAND EUROS).

SECOND: TO IMPOSE on I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U., with NIF A95075578, for a violation of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a fine of 1,000,000 euros (ONE MILLION EUROS).

THIRD: TO NOTIFY this resolution to I-DE REDES ELÉCTRICAS INTELIGENTES, S.A.U.

FOURTH: This resolution shall be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has elapsed without the interested party having exercised this right. The sanctioned party is warned that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, in the restricted account No. IBAN: ES00-0000-0000-0000-0000-0000, opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period. Upon receipt of the notification and once it is enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second month following or the next business day thereafter.

In accordance with the provisions of Article 76.4 of the LOPDGDD and given that the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the violation committed, and the amount of the sanction will be published in the Official State Gazette.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative route in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a

contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and in paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es